

Rastro: extensão Firefox para detecção de rastreadores

Avaliação Intermediária de Cibersegurança, Insper. Mateus Porto Pereira de Paiva, matrícula 23620308.

Repositório: github.com/Mateus-PortoPP/cyber_PI

1. O que a extensão faz

A Rastro é uma extensão para Firefox (Manifest V2) que mostra, para cada aba, o que a página está fazendo com a privacidade de quem navega: conexões a domínios de terceira parte, cookies injetados (primeira ou terceira parte, sessão ou persistentes), uso de armazenamento HTML5 (localStorage, sessionStorage e IndexedDB), canvas fingerprint, bounce tracking, cookie sync e parâmetros de rastreo na URL. No fim ela calcula uma nota de privacidade de 0 a 100. A instalação via `about:debugging` está explicada no `README.md` do repositório.

Componente	Como é detectado
Terceira parte	Em <code>webRequest.onBeforeRequest</code> , o eTLD+1 da requisição é comparado com o eTLD+1 da página da aba. A lista de sufixos está em <code>lib/psl.js</code> (versão reduzida da Public Suffix List).
Cookies	Duas fontes: os cabeçalhos <code>Set-Cookie</code> em <code>onHeadersReceived</code> (o que o servidor tentou gravar) e <code>cookies.onChanged</code> (o que o navegador gravou de fato, inclusive via <code>document.cookie</code>). Cookie de terceira parte é o que tem eTLD+1 diferente do site da aba ou que vem particionado (<code>partitionKey</code>). Sessão ou persistente vem do campo <code>session</code> .
Armazenamento HTML5	O <code>content.js</code> roda em todos os frames e lê as chaves e o tamanho (nunca os valores) no carregamento e a cada 2 segundos. As aberturas de IndexedDB são interceptadas na hora da chamada.
Canvas fingerprint	O <code>content.js</code> intercepta, com <code>exportFunction</code> , as funções <code>toDataURL</code> , <code>toBlob</code> , <code>getImageData</code> , <code>convertToBlob</code> (OffscreenCanvas) e <code>readPixels</code> (WebGL). É considerada suspeita a leitura de um canvas de pelo menos 16×16 em que foi desenhado texto, ou de um canvas WebGL. A marca de "tem texto" acompanha cópias feitas com <code>drawImage</code> e <code>transferToImageBitmap</code> .
Bounce tracking	O background guarda o histórico da aba. Conta como bounce um salto por redirect HTTP (mesmo <code>requestId</code>), uma página que saiu sozinha por JavaScript ou meta refresh (qualificador <code>client_redirect</code>), ou uma página aberta por link que saiu em menos de 10 segundos sem interação do usuário, sempre com eTLD+1 diferente do destino.
Cookie sync e parâmetros	Um mesmo valor com cara de identificador (8 caracteres ou mais, ignorando timestamps e a URL da página) enviado a dois ou mais terceiros; valor de cookie aparecendo na URL de um terceiro; redirect entre terceiros carregando um ID; e uma lista de parâmetros de rastreo conhecidos (<code>utm_*</code> , <code>fbclid</code> , <code>gclid</code> , <code>msclkid</code> etc.).

2. Ambiente e método dos testes

- Firefox 156 no macOS, com a proteção aprimorada contra rastreamento no nível Padrão. Essa configuração não foi alterada em nenhum teste. A extensão foi carregada como temporária.
- A extensão precisa estar carregada antes de abrir a página. O background só vê o que acontece depois que ele existe. No primeiro teste, com a página já aberta, o popup mostrou zero terceiros; depois de recarregar, o `doubleclick.net` apareceu.
- As páginas que gravam dados foram testadas sem dados anteriores do site (cadeado na barra de endereço, "Limpar cookies e dados do site"), porque o plugin mede o que é gravado na visita, e com dados anteriores a contagem muda. A exceção foi a Wikipédia, em que o HAR mostra que a limpeza não foi feita antes da visita medida (seção 4.1).
- Cada teste foi feito na própria aba. Outras abas aparecem abertas em alguns prints (Wikipédia e gov.br durante testes do DDG e do DuckDuckGo); como o relatório é por aba e a atribuição de cookies é por domínio, essas abas só interfeririam se compartilhassem domínio com a página testada, o que não acontece entre esses sites.
- O uBlock Origin foi instalado para a análise dos sites reais e ficou desligado em todos os testes do plugin. Nos prints, o ícone cinza do uBlock na barra indica que ele estava desligado; quando ligado, o ícone fica vermelho com o contador de bloqueios, como nos prints `*_ublock.png`. Bloqueio do uBlock aparece na aba Rede como "Bloqueado por uBlock Origin"; erros como `NS_ERROR_DOM_NETWORK` ou `NS_ERROR_CORRUPTED_CONTENT` são falhas da própria requisição, não bloqueio.
- A validação foi feita com as abas Rede e Armazenamento do DevTools e com `browser.cookies.getAll({partitionKey:{}})`. Quando uma página de teste mostrou falhas, o teste foi repetido com a extensão removida, para confirmar que a falha não era causada por ela.

3. Entregável 2: DuckDuckGo Privacy Test Pages

Site: `https://privacy-test-pages.site`. Pelo README oficial, os domínios de teste são `bad.third-party.site` (rastreador que o DDG bloqueia), `broken.third-party.site` (rastreador que não é bloqueado) e `good.third-party.site` (terceiro que não rastreia). Os três têm o mesmo eTLD+1, `third-party.site`, e isso explica parte das divergências abaixo. Quando a página não reporta um resultado, o "esperado" é o comportamento descrito no título ou no código dela.

3.1 Tabela de resultados

Teste	Esperado (reportado pela página)	Resultado do plugin	Explicação da divergência
-------	----------------------------------	---------------------	---------------------------

Tracker Reporting: 1 major tracker loaded via script Figuras 1, 8	1 rastreador: <code><script src="//doubleclick.net/tracker.js"></code>	doubleclick.net, 1 requisição, tipo <code>script</code> . Nota 98.	A detecção bate. A diferença aparece na aba Rede (figura 8): a requisição a <code>doubleclick.net/tracker.js</code> saiu e voltou com tipo <code>html</code> , 0 B e <code>NS_ERROR_CORRUPTED_CONTENT</code> . Ou seja, o domínio real não serve esse arquivo como JavaScript e o Firefox recusou executar a resposta como script. O ícone de escudo ao lado do domínio mostra que o Firefox o reconhece como rastreador, mas no nível Padrão a proteção só bloqueia cookies de rastreamento, não o script. O plugin registra a requisição porque ela de fato foi feita; para o plugin, o que importa é a tentativa de conexão ao terceiro, não se o script rodou.
Tracker Reporting: 1 major tracker with surrogate Figura 2	1 rastreador (<code>doubleclick.net</code>), que o DDG trocava por um script inofensivo (surrogate)	doubleclick.net, 1 requisição, <code>script</code> . Nota 98.	O plugin não injeta surrogate, só observa. Por isso registra a requisição original ao rastreador.
Tracker Reporting: 1 major tracker loaded via img Figura 3	1 rastreador via <code></code>	facebook.com, 1 requisição, <code>image</code> , mais 1 cookie de terceira parte persistente. Nota 94 (–2 terceiro, –3 cookie de terceira parte, –1 persistente).	Sem divergência. O plugin ainda mostra que a resposta do pixel gravou um cookie de terceira parte.
Tracker Reporting: Image loaded via document fragment Figura 4	1 rastreador (<code>facebook.com</code>) criado via document fragment	facebook.com, 1 requisição, <code>image</code> . Nota 98.	Sem divergência. A forma de inserir o elemento no DOM não muda a requisição de rede.
Tracker Reporting: document fragment [Delay 5s] Figura 5	Mesmo rastreador, inserido 5 segundos depois do carregamento	facebook.com, 1 requisição, <code>image</code> . Nota 98.	Sem divergência. O listener de rede fica ativo a vida inteira da página, não só no carregamento.
Tracker Reporting: 1 major tracker loaded via fetch Figura 6	A página mostra "Tracker loaded" (fetch para <code>facebook.com</code>)	facebook.com, 1 requisição, tipo <code>xmlhttprequest</code> . Nota 98.	Sem divergência. O Firefox classifica <code>fetch()</code> como <code>xmlhttprequest</code> no <code>webRequest</code> .
Tracker Reporting: via fetch [Delay 5s] Figura 7	"Tracker loaded", 5 segundos depois do carregamento	facebook.com, 1 requisição, <code>xmlhttprequest</code> . Nota 98.	Sem divergência, mesmo caso do delay acima.

Storage blocking Figuras 9, 10, 11, 12	"Stored random number ... using 23 storage mechanisms (1 failed)". A falha é o WebSQL (openDatabase is not defined)	2 domínios de terceira parte (third-party.site, com good e broken, e ad-company.site); 24 cookies gravados (17 de terceira parte, 7 de primeira, todos persistentes); armazenamento na página e nos iframes good, broken e ad-company (3 origens de terceira parte, 4 frames). Na execução 443 (figuras 10 e 11), a mesma contagem: 24 gravados, 7 de primeira e 17 de terceira parte, com apenas 9 Set-Cookie recebidos, porque a maioria dos cookies é gravada por JavaScript (document.cookie) e só aparece no cookies.onChanged. Nota 56 (–4 terceiros, –20 cookies de terceira parte, –10 persistentes, –10 armazenamento).	(1) WebSQL: o Firefox nunca implementou essa API. É limitação do navegador, não bloqueio. (2) O IndexedDB do iframe convert.ad-company.site fica vazio porque o iframe não consegue carregar /helpers/idb-wrapper.js (HTTP 404, conferido com curl -sI https://convert.ad-company.site/helpers/idb-wrapper.js) e a própria página mostra "DB is not defined". (3) Os cookies tptdata e tpsdata aparecem como primeira parte porque são gravados por scripts de broken. e good.third-party.site rodando no contexto da página, via document.cookie. O cookie recebe o domínio da página, a mesma técnica do _ga. (4) O DevTools da página não lista a origem dos iframes, que são removidos logo depois de gravar. O plugin vê os quatro frames porque lê de dentro de cada um. (5) Numa das execuções a página mostrou NetworkError nos testes de /set-cookie (status HTTP nulo) e o plugin contou 21 cookies, o mesmo que o cookies.getAll. Foi variação da página, não do plugin. (6) No iframe de anúncio, "first party header cookie: Request failed" aparece nas três execuções registradas (681, 443 e 31); na execução 31 (figura 12) aparece ainda "service worker cookieStore: Cannot GET .../service-worker-set-cookie", endpoint que responde 404. São falhas do servidor de teste, não do plugin.
Fingerprinting canvas verification Figuras 13, 14	Tabela pass/fail da página com 4 fail: 2 de "resistance" (esperam ruído anti-fingerprint) e 2 de "correctness" (comparação com uma imagem de referência)	Canvas fingerprint detectado: getImageData 122 leituras, 102 suspeitas; toDataURL 3 leituras, 0 suspeitas. Um terceiro, cloudflare.com (cdnjs.cloudflare.com, 1 script). Nota 78.	Os 4 fail aparecem iguais com a extensão removida, então não são causados pelo plugin. Os de "resistance" esperam que o navegador adicione ruído aleatório nos pixels, coisa que o Firefox no modo Padrão não faz e o plugin, que só observa, também não. Os de "correctness" comparam com uma imagem fixa, e a renderização muda de máquina para máquina. É justamente isso que torna o canvas fingerprint possível. Durante o desenvolvimento a primeira versão do hook quebrou todos os testes ("Permission denied to access property length"), porque o hook usava original.apply do mundo da página. A correção foi trocar por Reflect.apply.

Fingerprinting (Start the test) Figuras 15, 16	"Collected 124 datapoints (14 failed)". Entre eles há 4 testes de canvases: <code>canvas-2d-todataurl</code> , <code>canvas-2d-imagedata</code> , <code>canvas-2d-offscreen-todataurl</code> e <code>canvas-webgl</code> .	<code>toDataURL</code> : 4 leituras, 4 suspeitas; <code>getImageData</code> : 1 leitura, 1 suspeita. Canvas fingerprint detectado (–20). Nenhum terceiro, nenhum cookie; a própria página guarda uma chave <code>data</code> em <code>localStorage</code> , <code>sessionStorage</code> e <code>IndexedDB</code> , que é de primeira parte e não desconta. Nota 80.	Os 4 testes de canvases foram detectados, inclusive o do <code>OffscreenCanvas</code> , que desenha num canvas e lê de outro. A primeira versão não pegava esse; a marca passou a acompanhar <code>transferToImageBitmap</code> e <code>drawImage</code> . A página não chama <code>convertToBlob</code> nem <code>readPixels</code> em nenhum momento. Os outros 120 datapoints (<code>navigator</code> , <code>screen</code> , parâmetros WebGL, cabeçalhos) ficam fora do que foi pedido, que era canvases.
Tracker Blocking Figura 17	A página pede para colocar <code>bad.third-party.site</code> na lista de bloqueio e espera as 23 requisições bloqueadas. Resultado: 22 carregaram (verde) e só o <code>websocket</code> falhou (vermelho).	1 domínio de terceira parte (–2), nenhum cookie, nenhum armazenamento de terceiros. Nota 98. O único terceiro da página é <code>third-party.site</code> , para onde a página envia as 23 requisições do teste.	O plugin é de detecção, não de bloqueio: não usa <code>webRequestBlocking</code> e não cancela nada. Por isso as 22 carregaram. O <code>websocket</code> falhou por conta própria, o plugin não interrompe requisição nenhuma.
Storage partitioning Figura 18	"Retrieved data from 21 storage mechanisms". <code>document.cookie</code> , HTTP Cookie e Cookie Store API deram fail (a página considera fail quando o dado gravado num contexto é lido no outro). <code>localStorage</code> , <code>sessionStorage</code> , <code>IndexedDB</code> , Cache API, <code>ServiceWorker</code> , <code>BroadcastChannel</code> , <code>SharedWorker</code> , Web Locks, os caches de <code>fetch</code> , <code>XHR</code> , <code>iframe</code> , imagem, favicon, fonte e CSS, e o HSTS deram pass (particionados). WebSQL e Prefetch Cache: unsupported.	Nota 95. 1 domínio de terceira parte (<code>privacy-test-pages.site</code> , 3 requisições de imagem, –2); 3 cookies gravados, nenhum de terceira parte, 3 persistentes (–3); 3 frames usando armazenamento.	A página grava um valor em cada mecanismo num contexto e tenta lê-lo de outro site; "pass" significa que o segundo contexto não enxergou o valor. Para isso ela precisa de mais de um contexto de topo. O plugin reinicia o relatório da aba a cada navegação de topo (<code>background.js</code> , <code>onBeforeRequest</code> com <code>type === "main_frame"</code>), então o popup mostra só o que a última página carregada fez: um terceiro (<code>privacy-test-pages.site</code> , 3 imagens), 3 frames do próprio site usando armazenamento (chaves <code>partition_test</code>), 3 cookies persistentes de primeira parte e nenhum <code>sub_frame</code> de outro site. O plugin não correlaciona o que um site gravou com o que outro leu, que é exatamente o que a página mede. Os três fail de cookie são comportamento do Firefox nessa página, não do plugin.

Bounce tracking (4 links) Figuras 19, 20	Cada link passa por <code>bad.third-party.site/.../bounce.html</code> , que grava um ID (cookie e localStorage) e redireciona por JavaScript (<code>location.href</code>) passando o ID na URL	<code>good.third-party.site</code> : nenhum bounce. <code>first-party.site</code> , <code>privacy-test-pages.site</code> e <code>publisher-company.site</code> : bounce por <code>bad.third-party.site</code> . No print (link "Go to first-party.site"): " <code>bad.third-party.site</code> , saída automática em poucos segundos, ficou 0.4 s, gravou 0 cookie(s)", nenhuma conexão a terceiro no destino, e a URL de destino ? <code>bounceUIDlocalStorage=83&bounceUIDcookie=83&isNew=</code> . Critério 6: -15.	(1) O destino <code>good.third-party.site</code> não é acusado porque intermediário e destino têm o mesmo eTLD+1, <code>third-party.site</code> . Pela regra do plugin, é o mesmo site. (2) O Firefox não marcou essa navegação com o qualificador <code>client_redirect</code> . A detecção veio da regra de reserva: página aberta por link que saiu em menos de 10 segundos sem interação. (3) "gravou 0 cookie(s)" e <code>isNew=</code> vazio no print: o ID 83 já existia em <code>bad.third-party.site</code> (a página mostra "cookie ID: 83" e "localStorage ID: 83"), porque um dos outros links já tinha passado por lá. O intermediário só grava cookie novo na primeira passagem; nas seguintes, ele lê o ID existente e o passa na URL. Ainda assim o bounce é detectado, porque a regra olha a navegação, não o cookie. (4) O <code>webRequest.onBeforeRedirect</code> não vê esse salto, porque a página responde HTTP 200 e redireciona por script. Só o <code>webNavigation</code> vê. (5) O ID que o DDG usa vai de 1 a 101, curto demais para contar como cookie sync (mínimo de 8 caracteres).
Query parameters (4 links) Figura 21	Quatro links de <code>privacy-test-pages.site</code> para a landing <code>good.third-party.site/.../query.html</code> , com <code>utm_source</code> ; com <code>utm_source</code> e <code>utm_medium</code> ; com <code>fbclid</code> e <code>fb_source</code> (mais o parâmetro comum <code>u=14</code>); e um link só com parâmetros comuns, que não deve ser alterado. Um navegador com proteção (o do DDG) removeria os parâmetros de rastreo	Parâmetros detectados, na ordem dos links: <code>utm_source</code> ; <code>utm_source</code> , <code>utm_medium</code> ; <code>fbclid</code> , <code>fb_source</code> ; nenhum. No print (terceiro link): "Parâmetros de rastreo na URL: <code>fbclid</code> , <code>fb_source</code> ", com o <code>u=14</code> da mesma URL ignorado. Os parâmetros comuns (<code>q</code> , <code>u</code> , <code>id</code>) nunca foram acusados.	O "Results" da página mostra que os parâmetros chegaram: o Firefox no nível Padrão não os removeu. O plugin não reescreve URL, só detecta e desconta na nota.

3.2 Prints do plugin em execução

Cada linha da tabela 3.1 indica as figuras correspondentes.

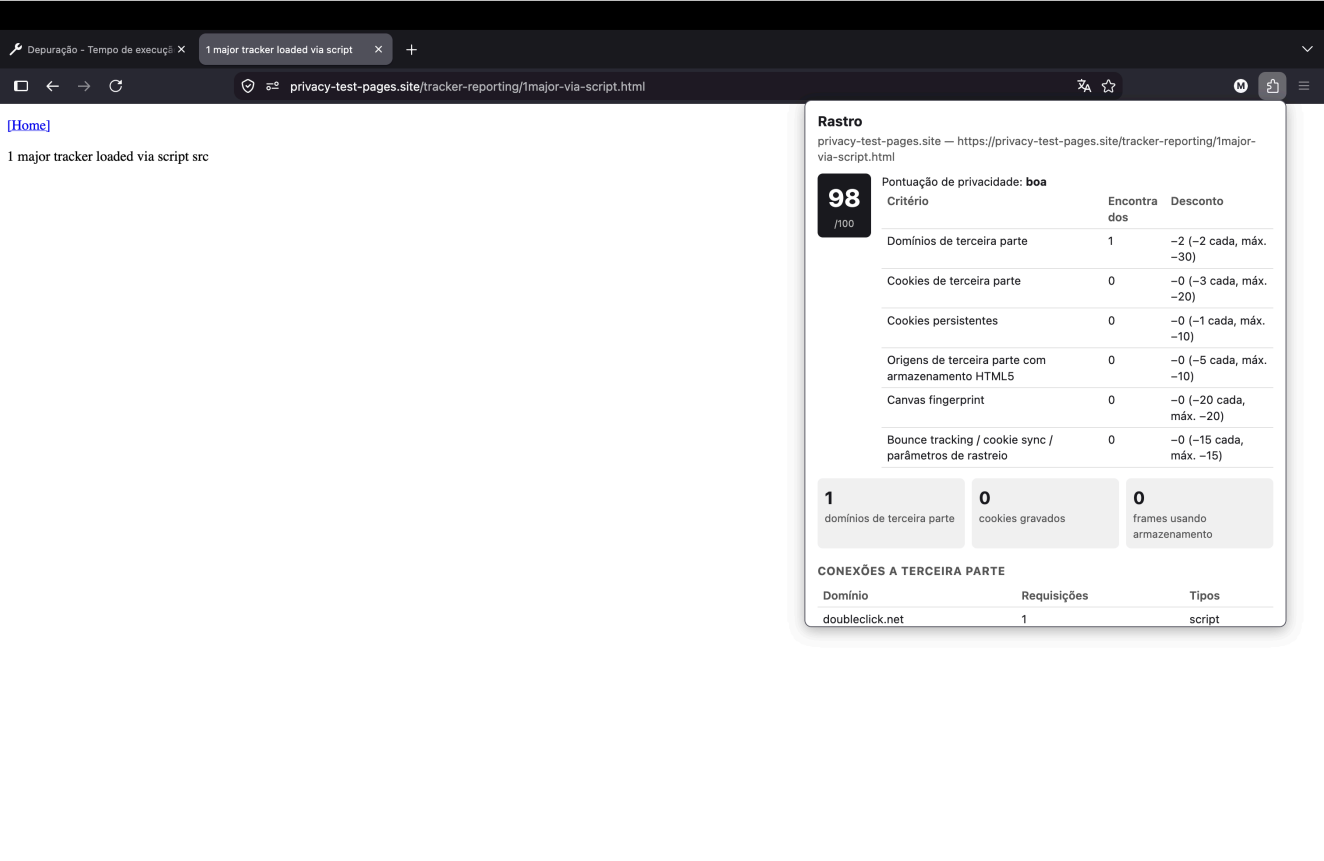


Figura 1. Tracker Reporting, via script

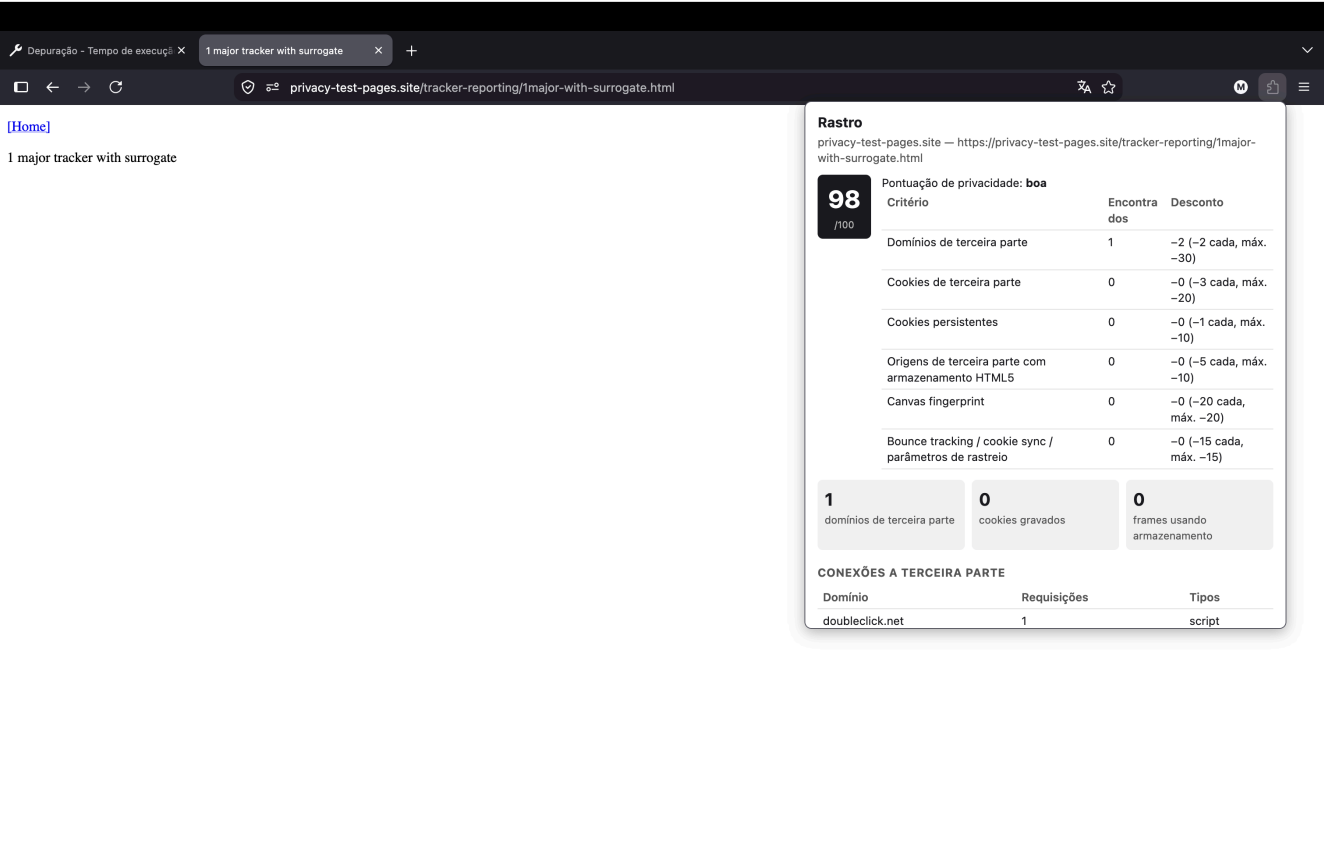


Figura 2. Tracker Reporting, with surrogate

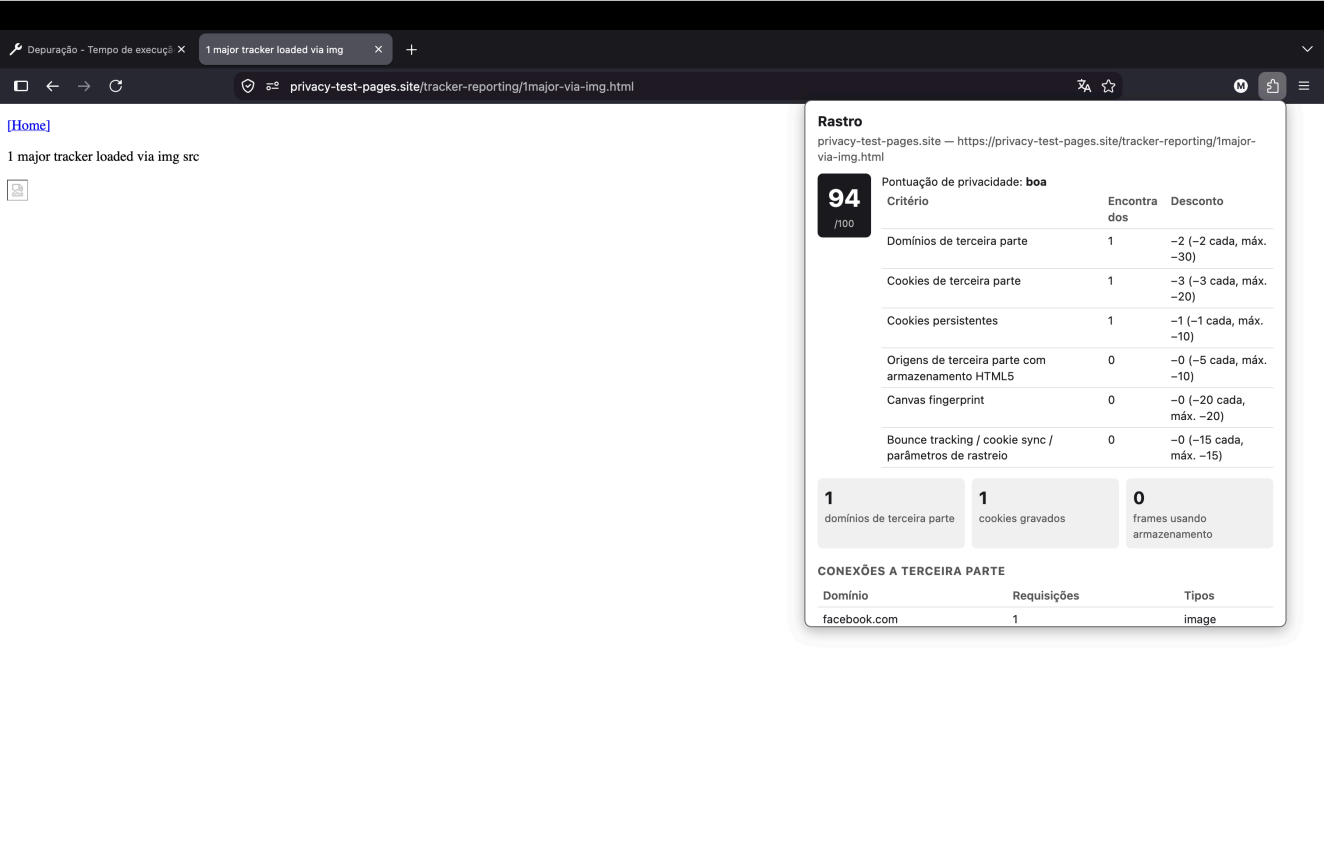


Figura 3. Tracker Reporting, via img

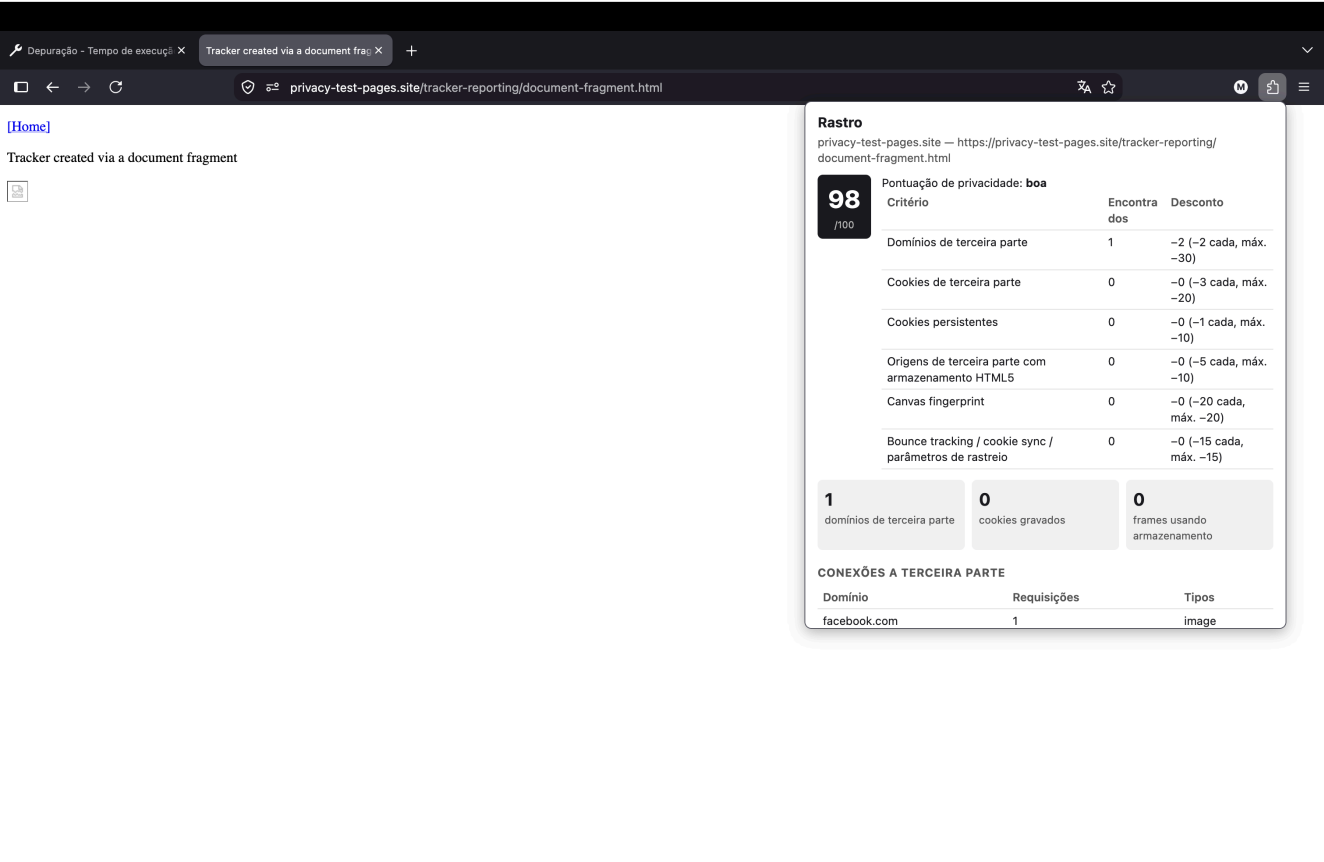


Figura 4. Tracker Reporting, document fragment

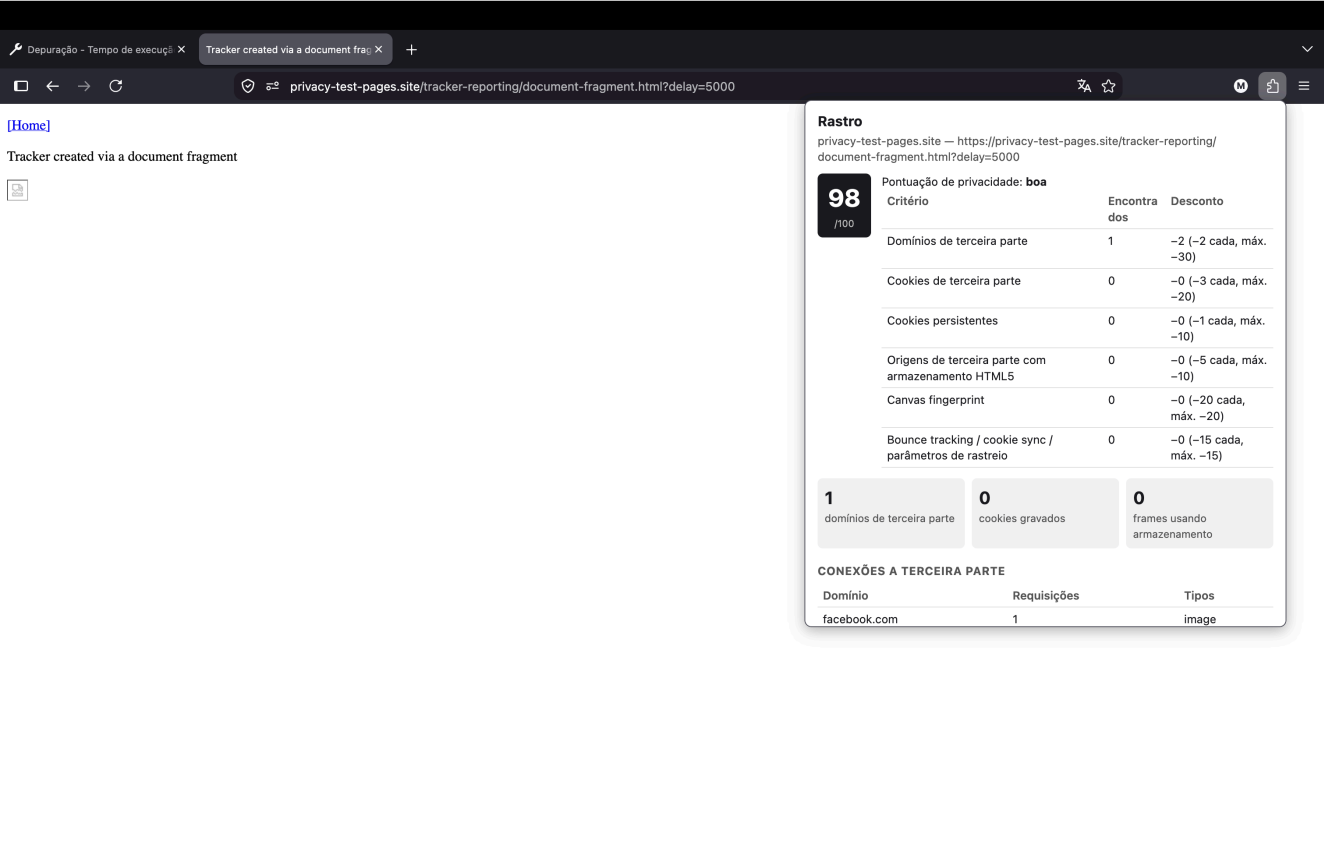


Figura 5. Tracker Reporting, document fragment com delay de 5 s

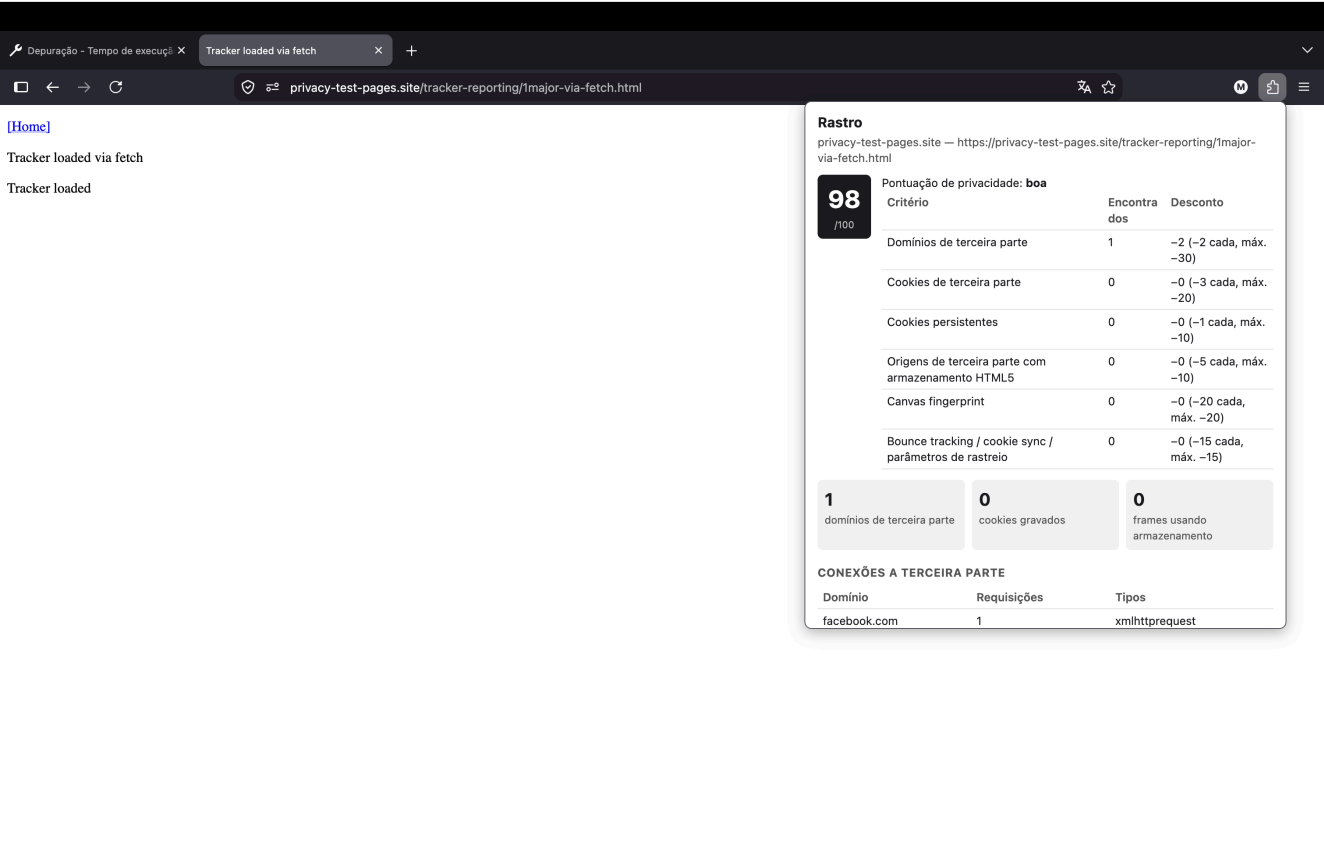


Figura 6. Tracker Reporting, via fetch

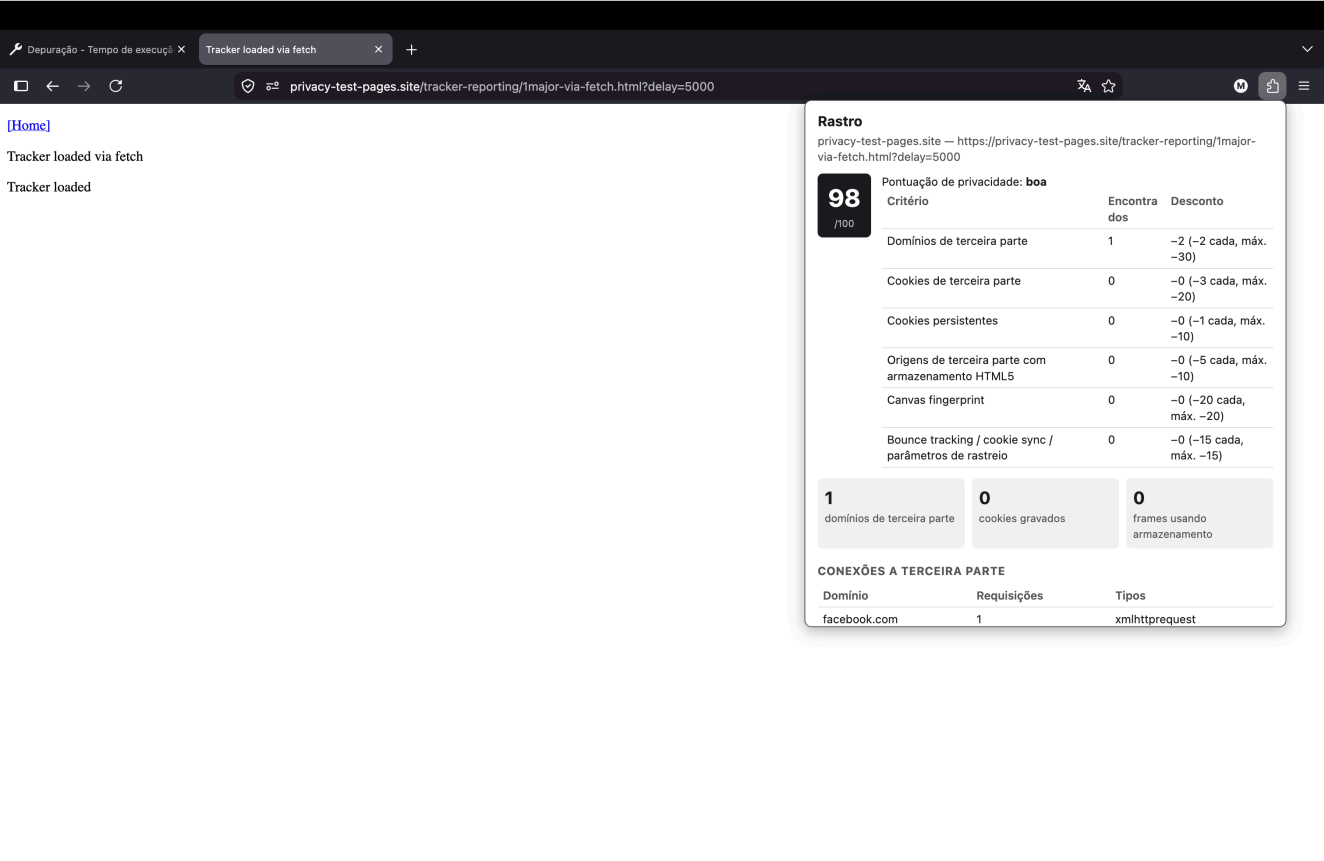


Figura 7. Tracker Reporting, via fetch com delay de 5 s

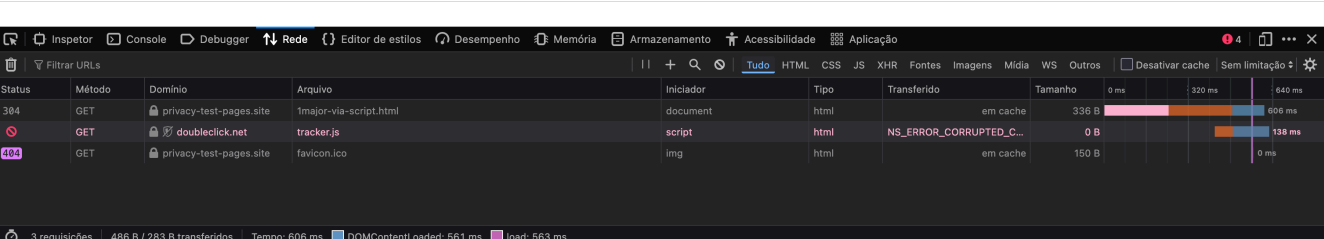


Figura 8. Aba Rede (validação): a requisição a doubleclick.net/tracker.js sai e volta como html com NS_ERROR_CORRUPTED_CONTENT

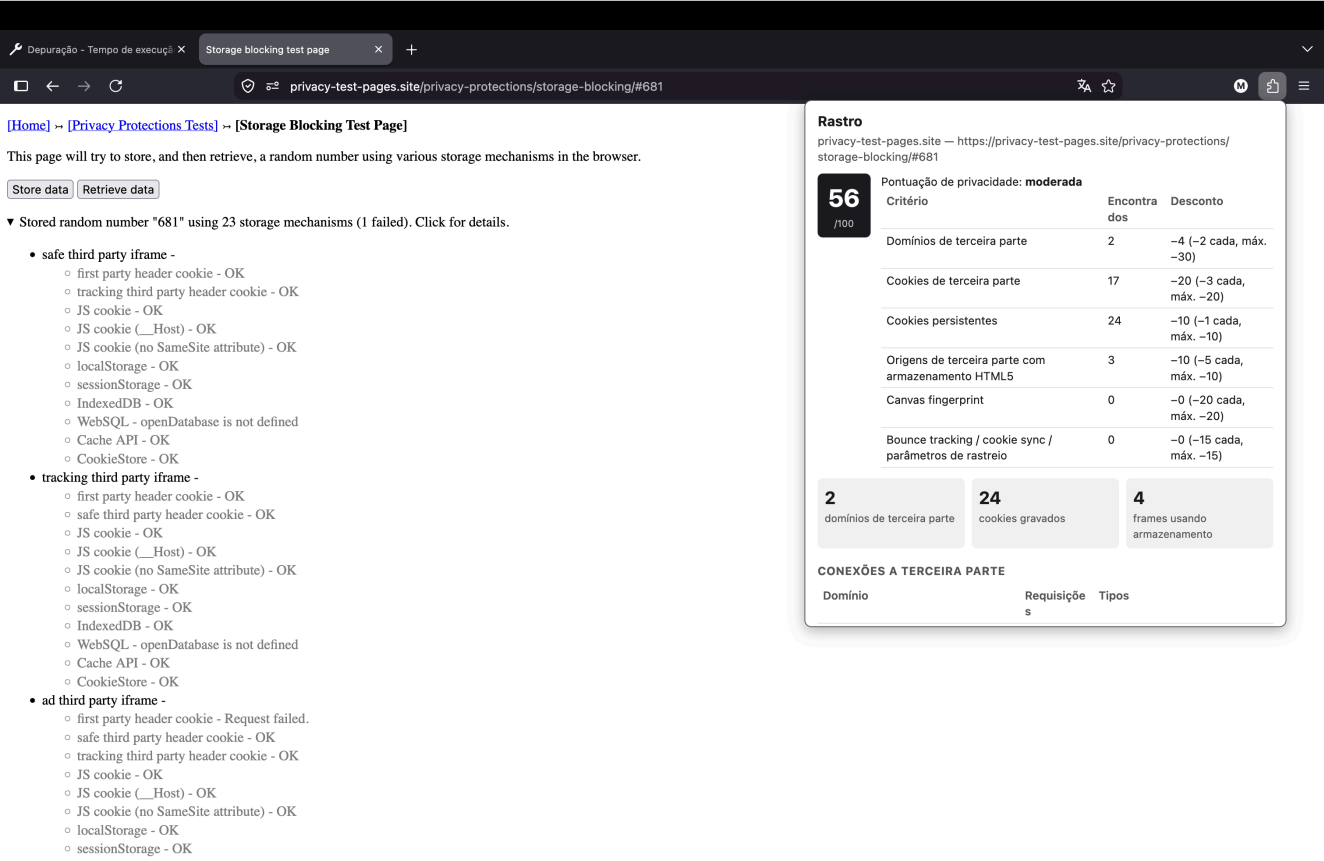


Figura 9. Storage blocking (execução 681)

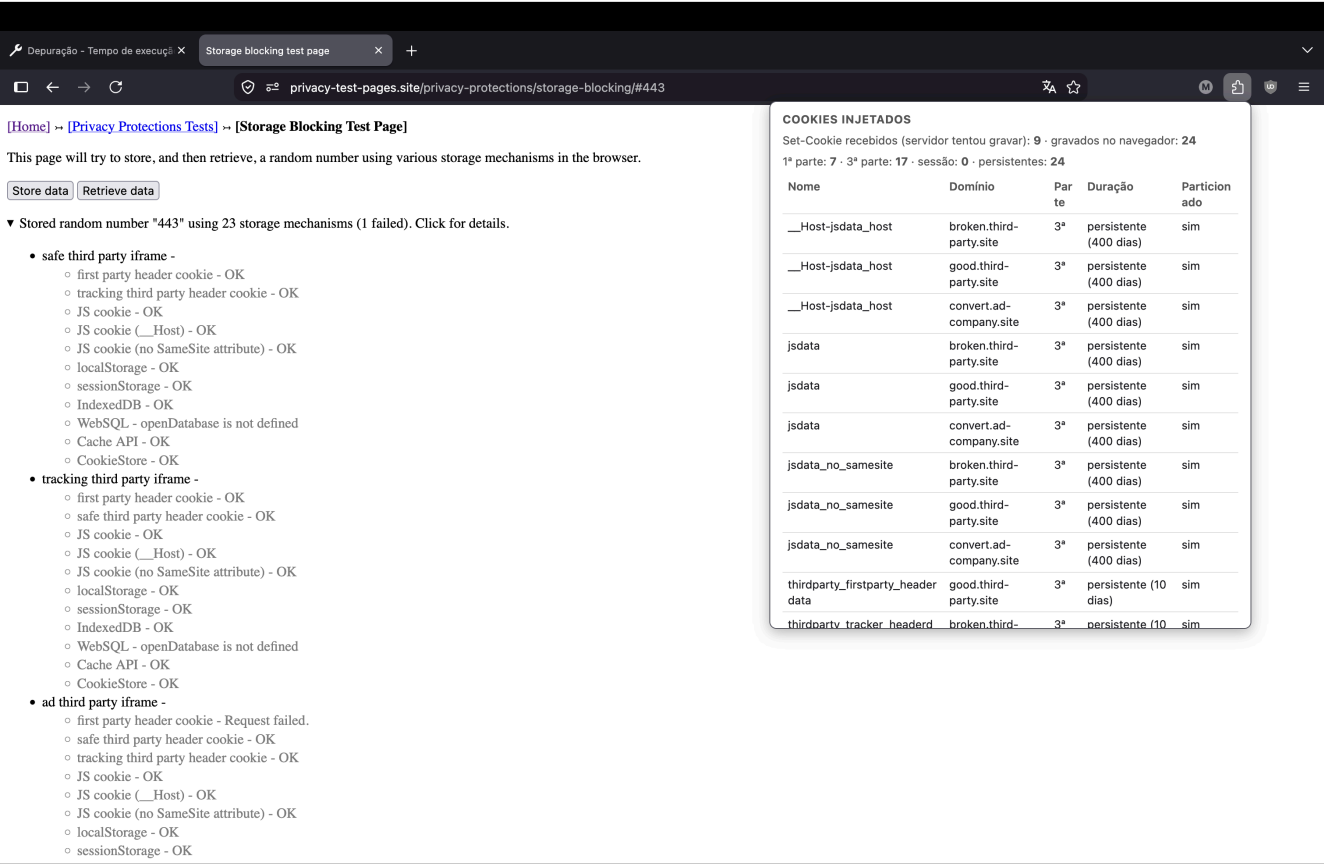


Figura 10. Storage blocking (execução 443), popup rolado: contagem de cookies e a lista de cookies de terceira parte

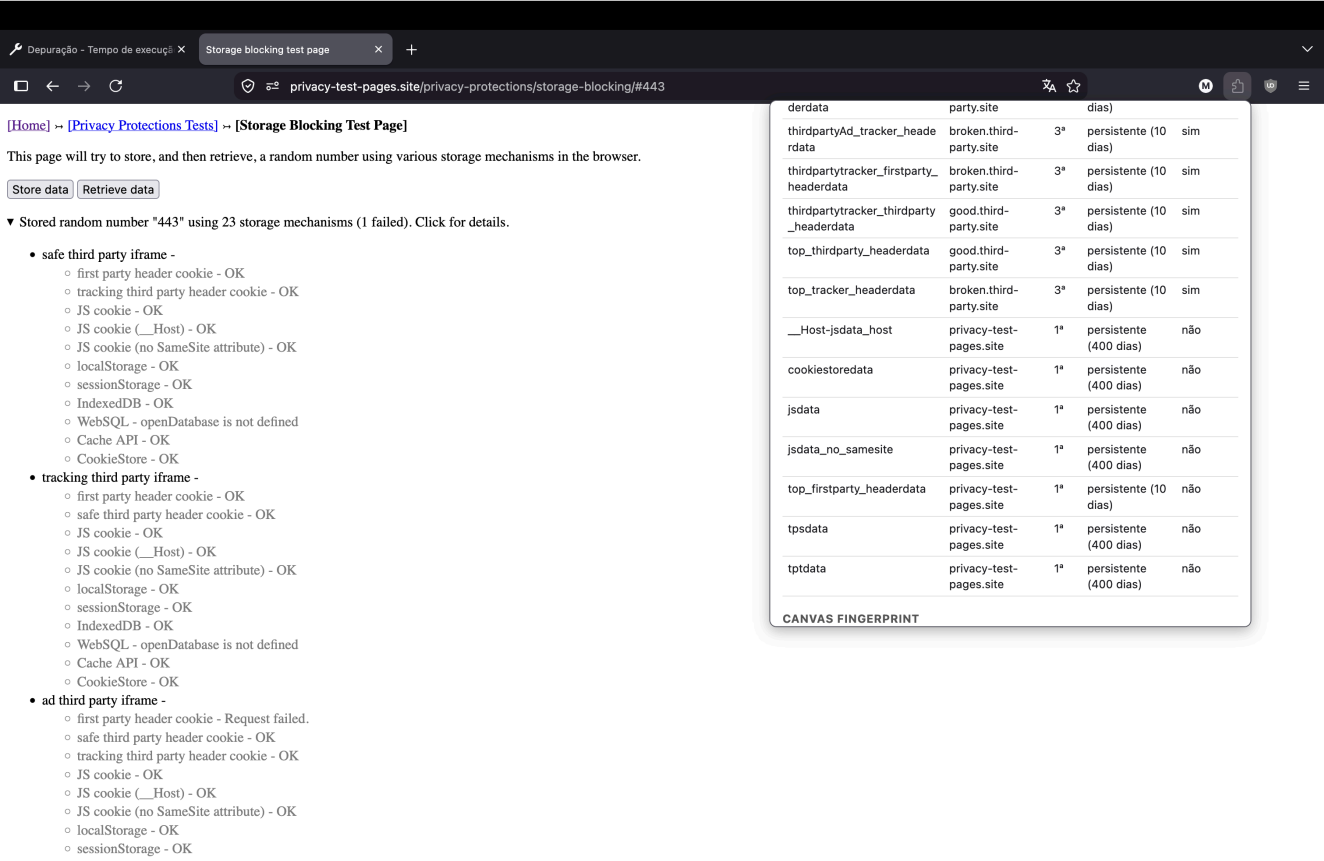


Figura 11. Storage blocking (execução 443), continuação da lista: tptdata e tpsdata como primeira parte

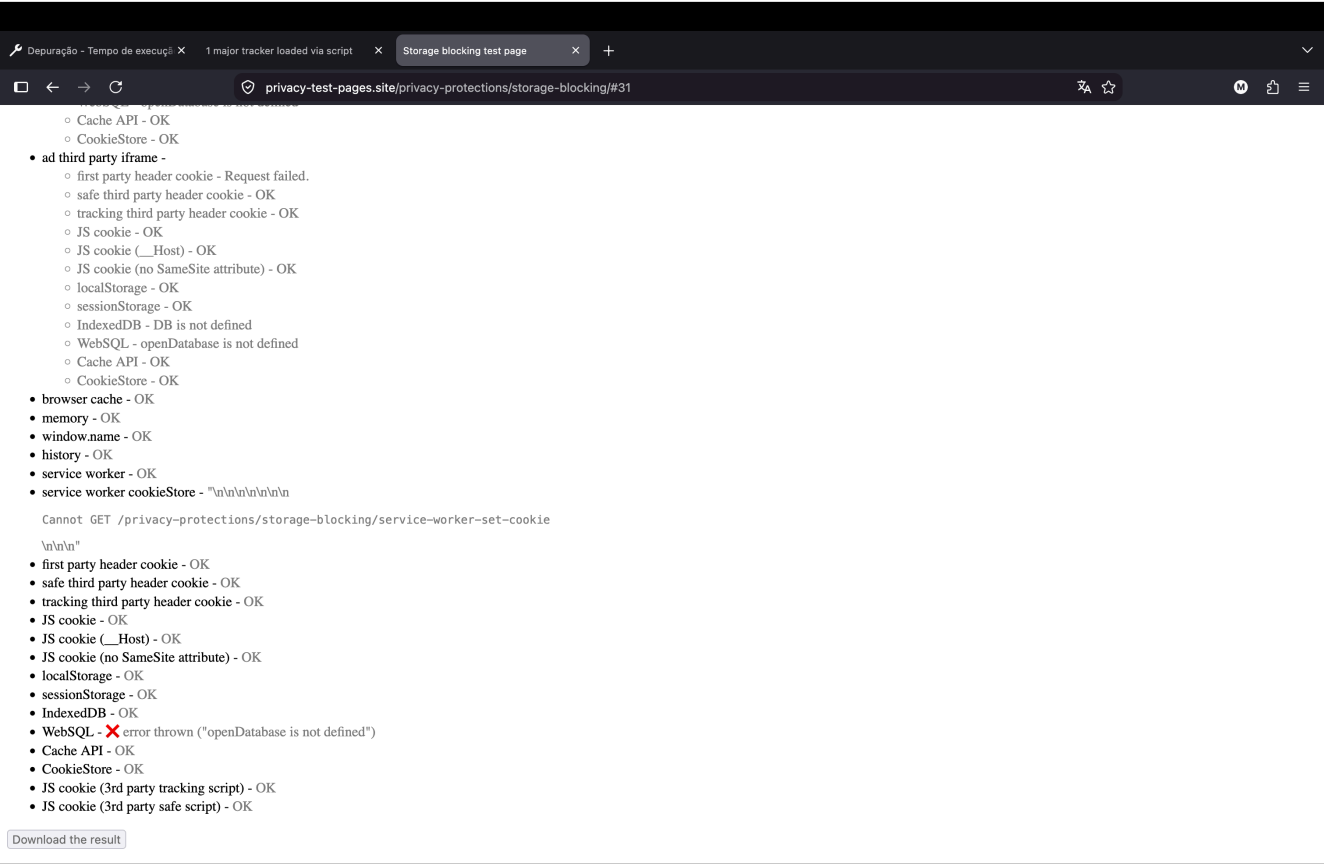


Figura 12. Storage blocking, detalhes da página numa execução anterior (número 31), com o WebSQL e o endpoint service-worker-set-cookie falhando

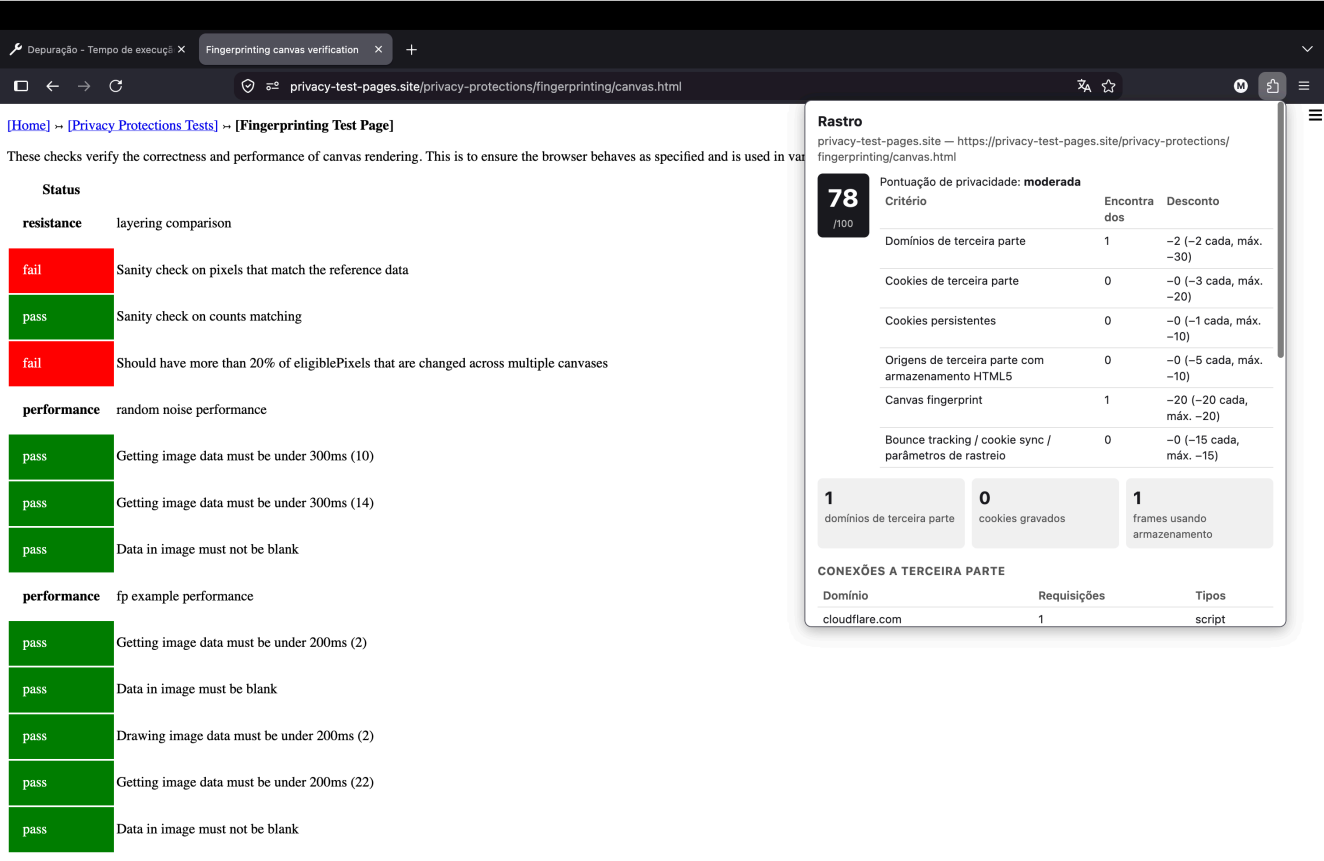


Figura 13. Fingerprinting canvas verification

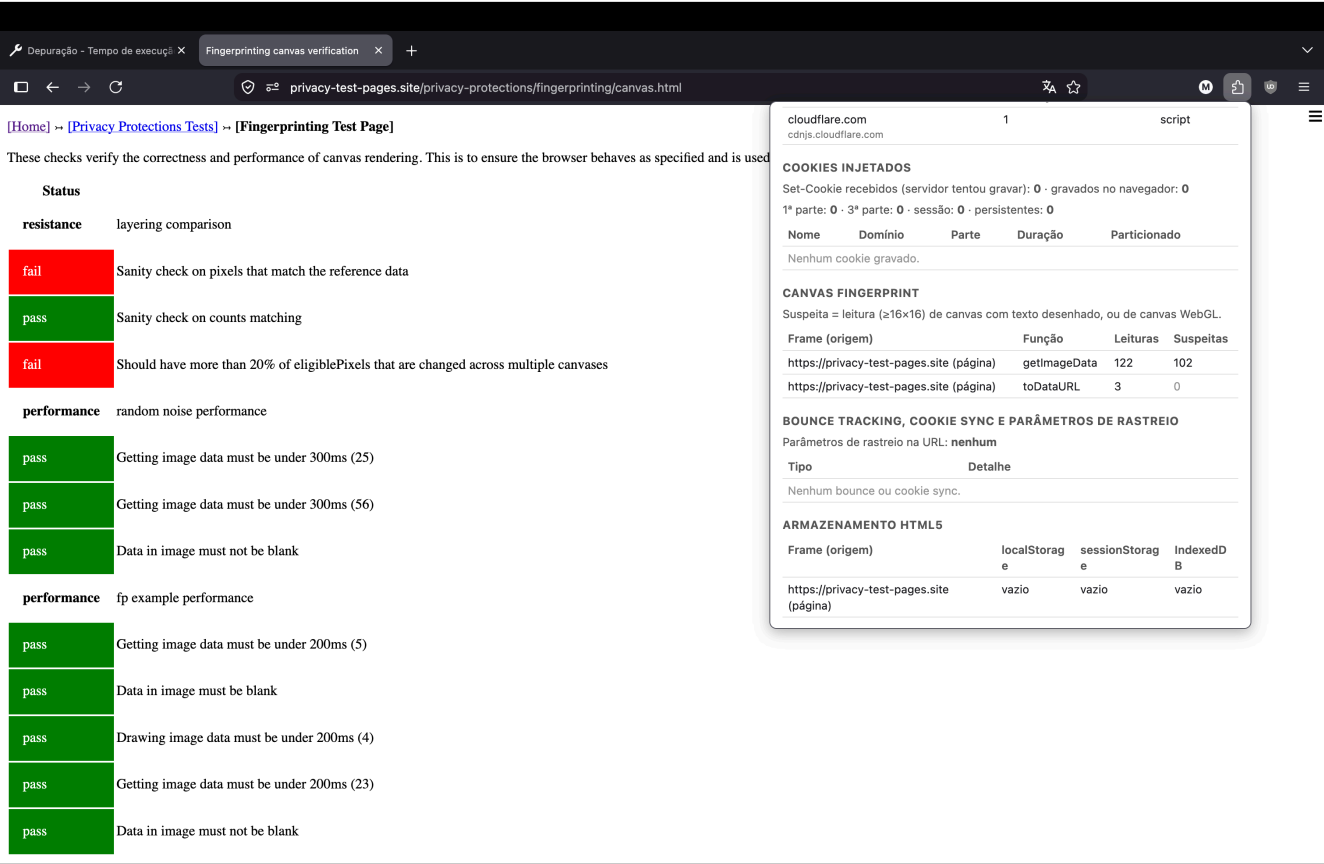


Figura 14. Fingerprinting canvas verification, execução posterior com o popup rolado: leituras de canvas (getImageData 122/102, toDataURL 3/0), mesmo terceiro e mesma detecção

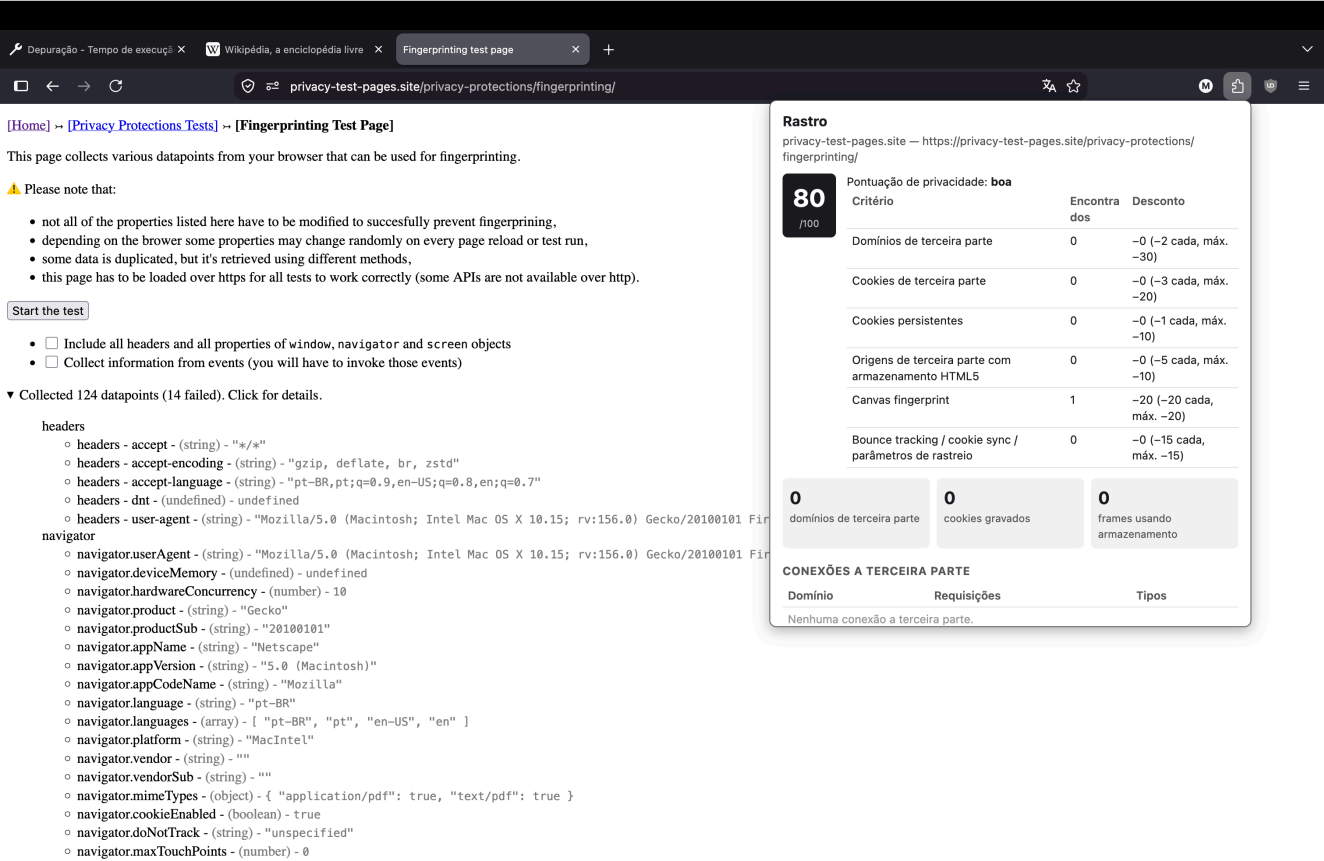


Figura 15. Fingerprinting

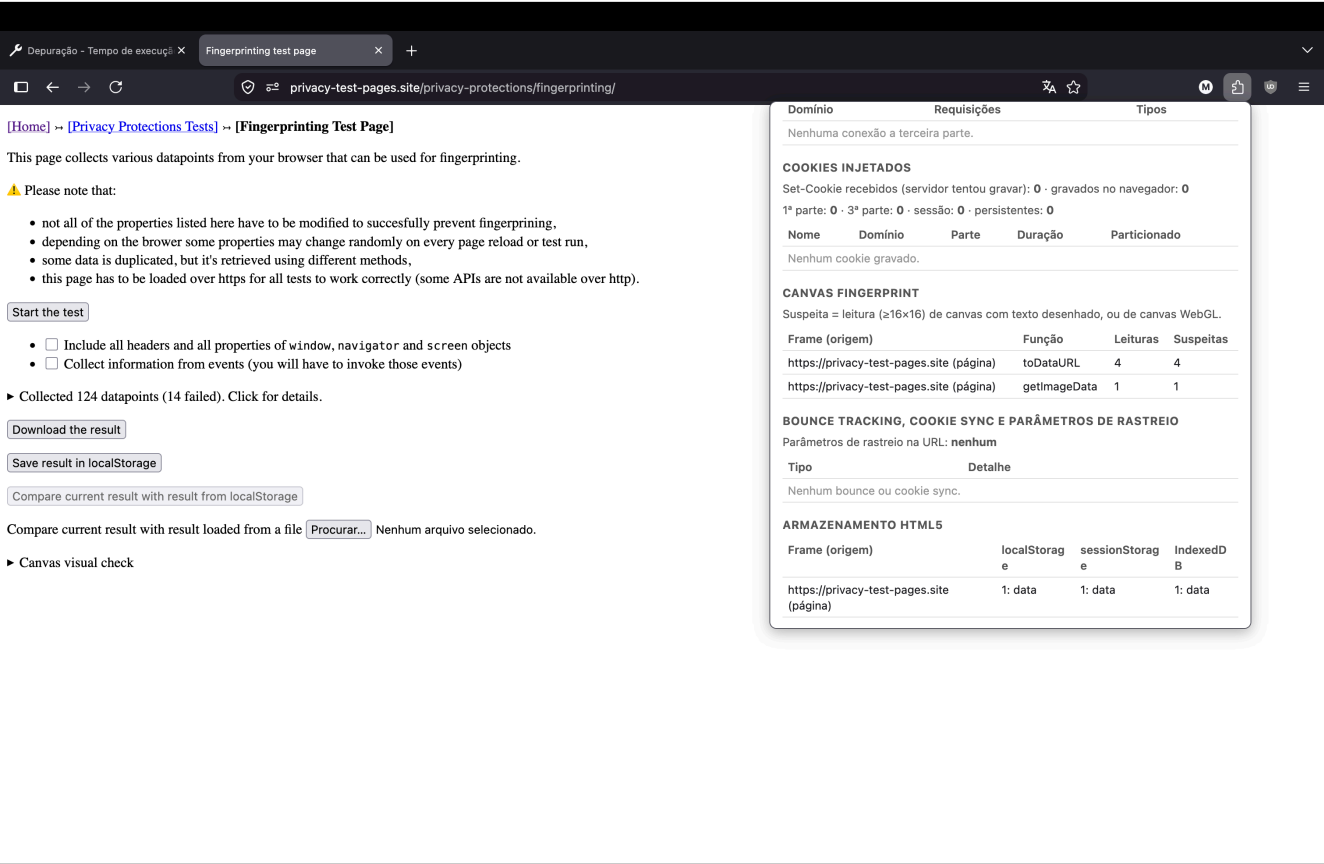


Figura 16. Fingerprinting, popup rolado: leituras de canvas (toDataURL 4/4, getImageData 1/1) e armazenamento da própria página

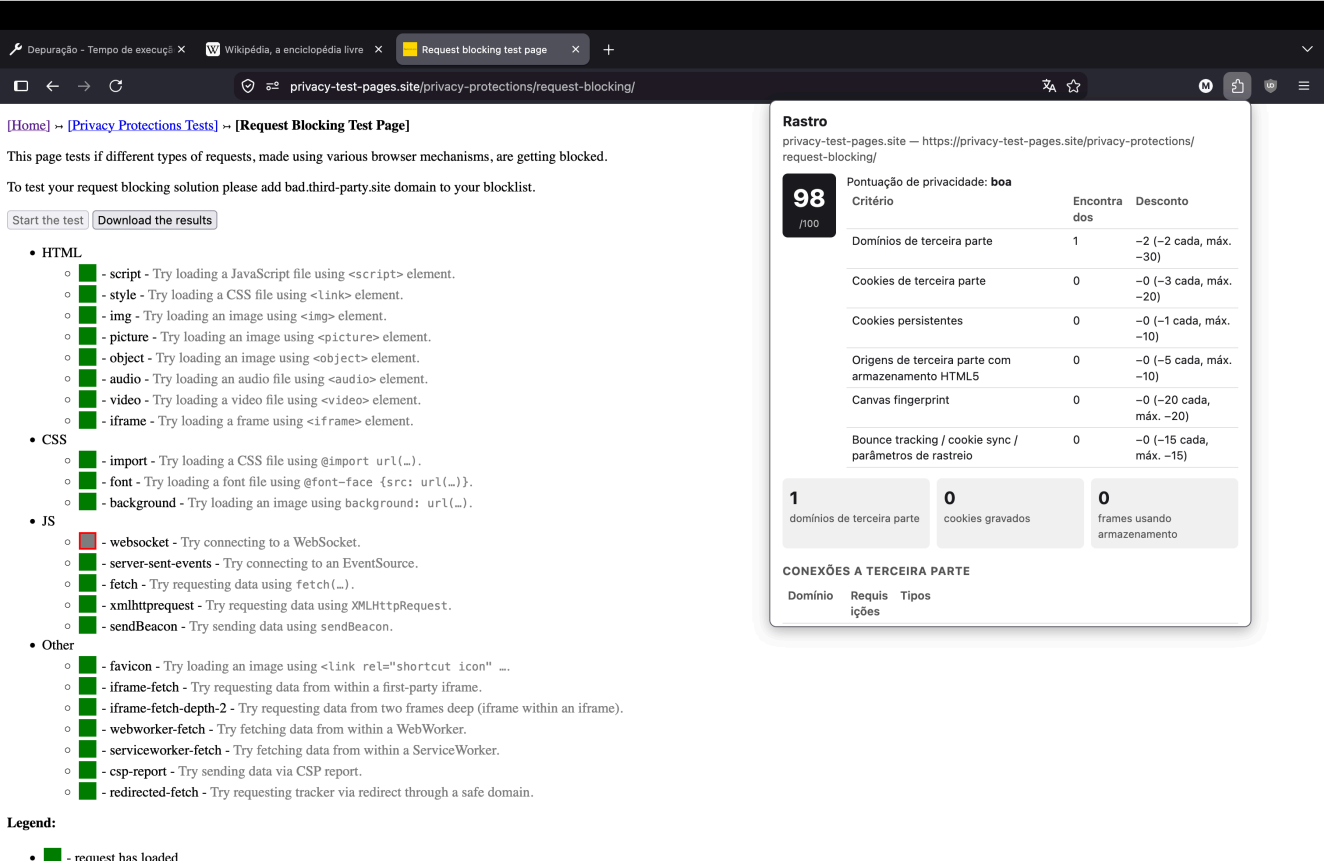


Figura 17. Tracker Blocking

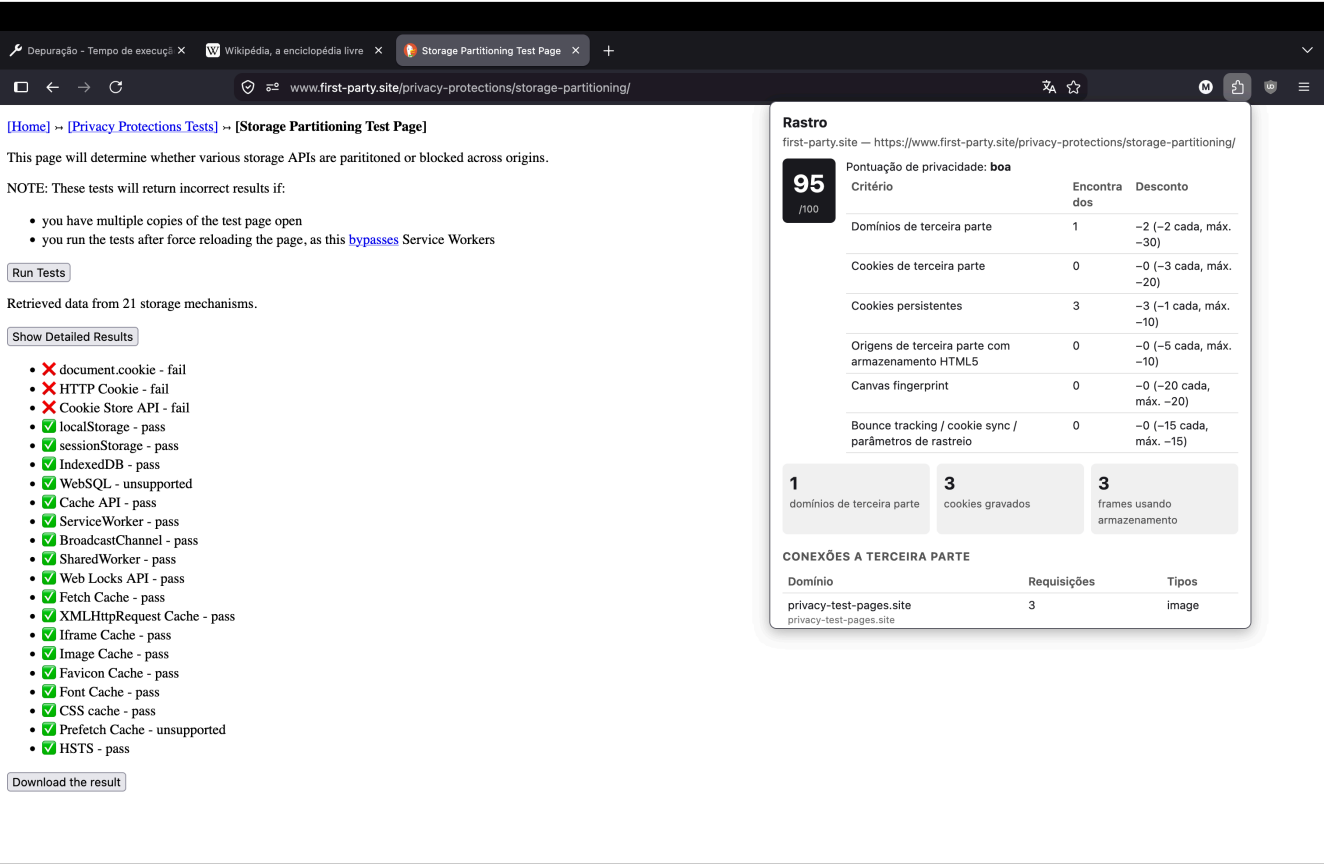


Figura 18. Storage partitioning

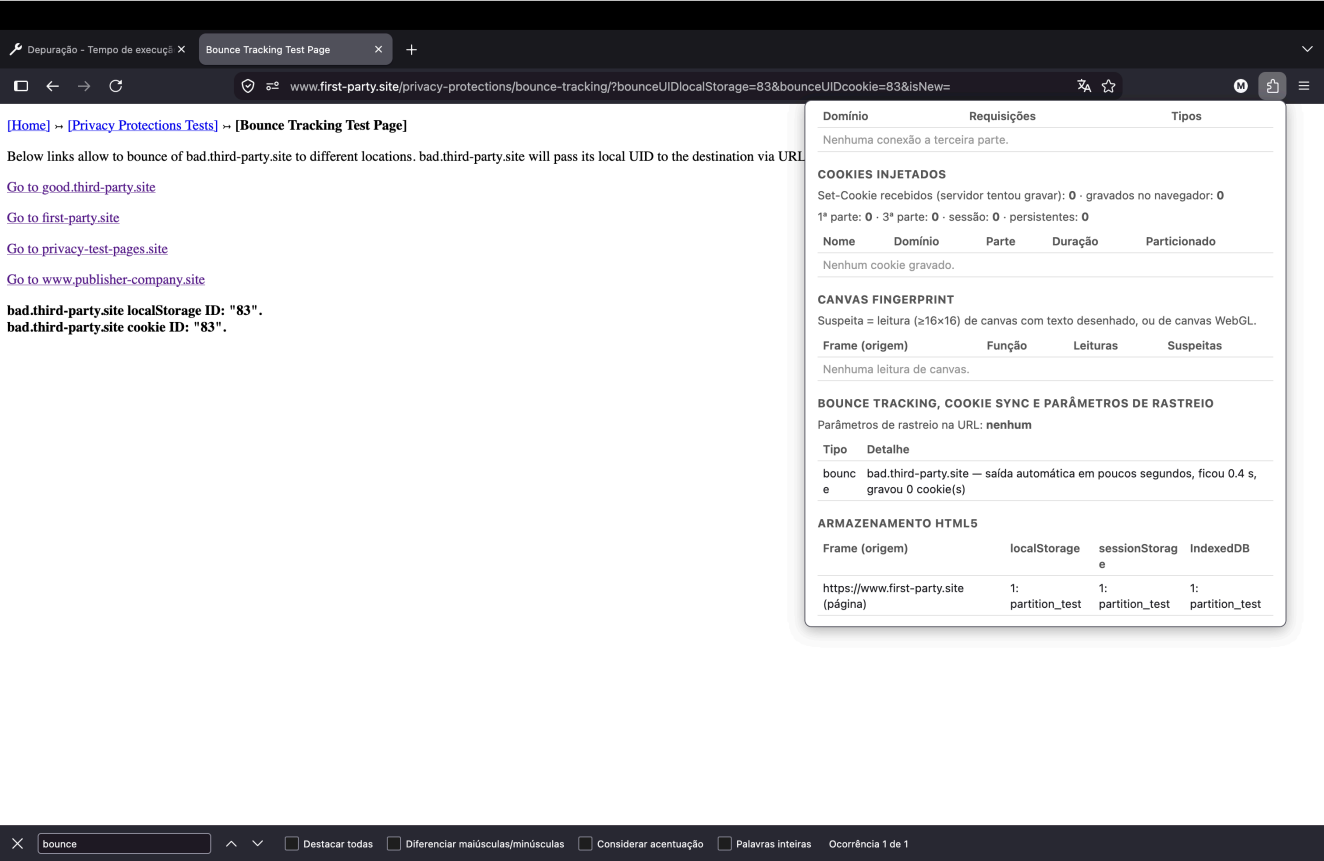


Figura 19. Bounce tracking, Go to first-party.site (ID 83 já existente no intermediário: isNew vazio, 0 cookies gravados)

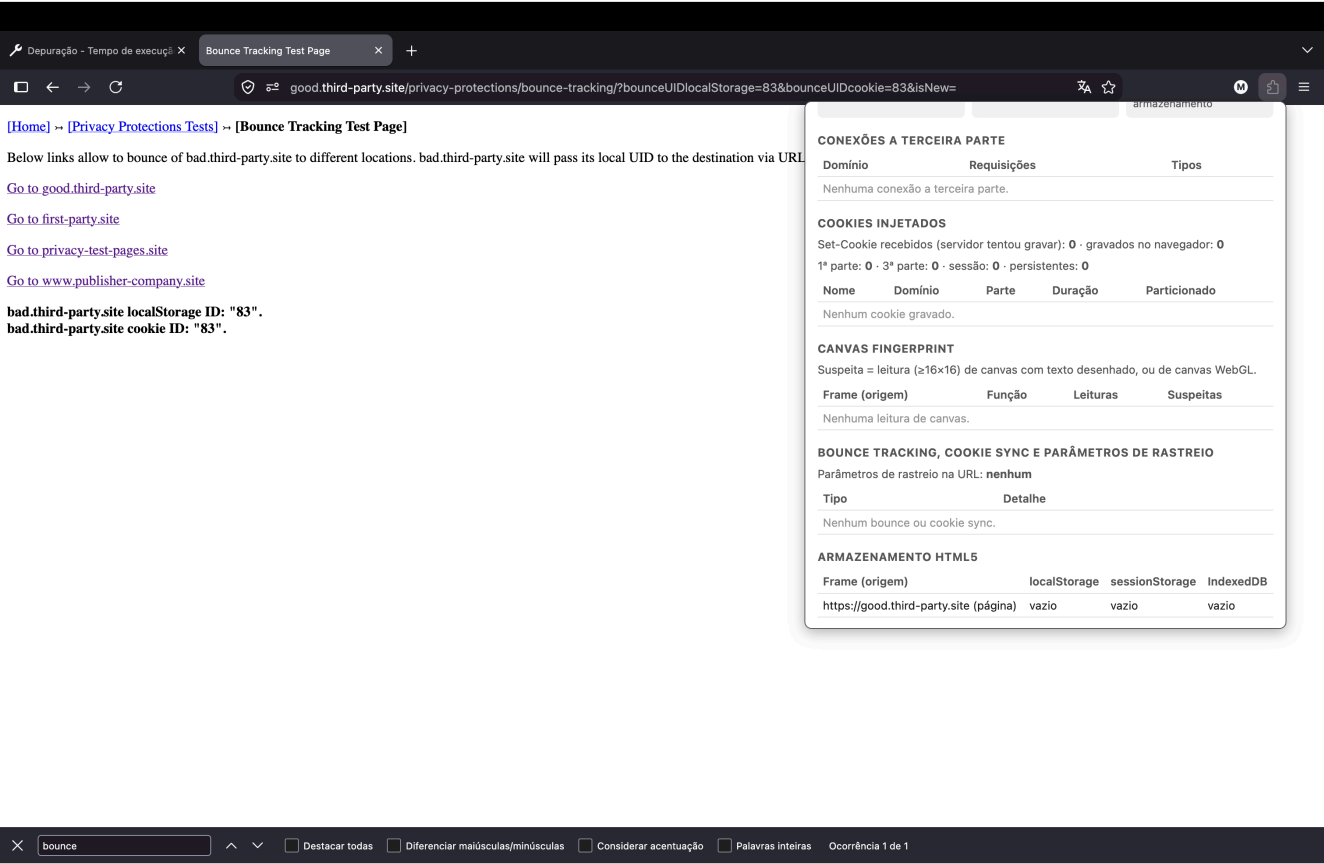


Figura 20. Bounce tracking, Go to good.third-party.site (sem bounce, mesmo eTLD+1)

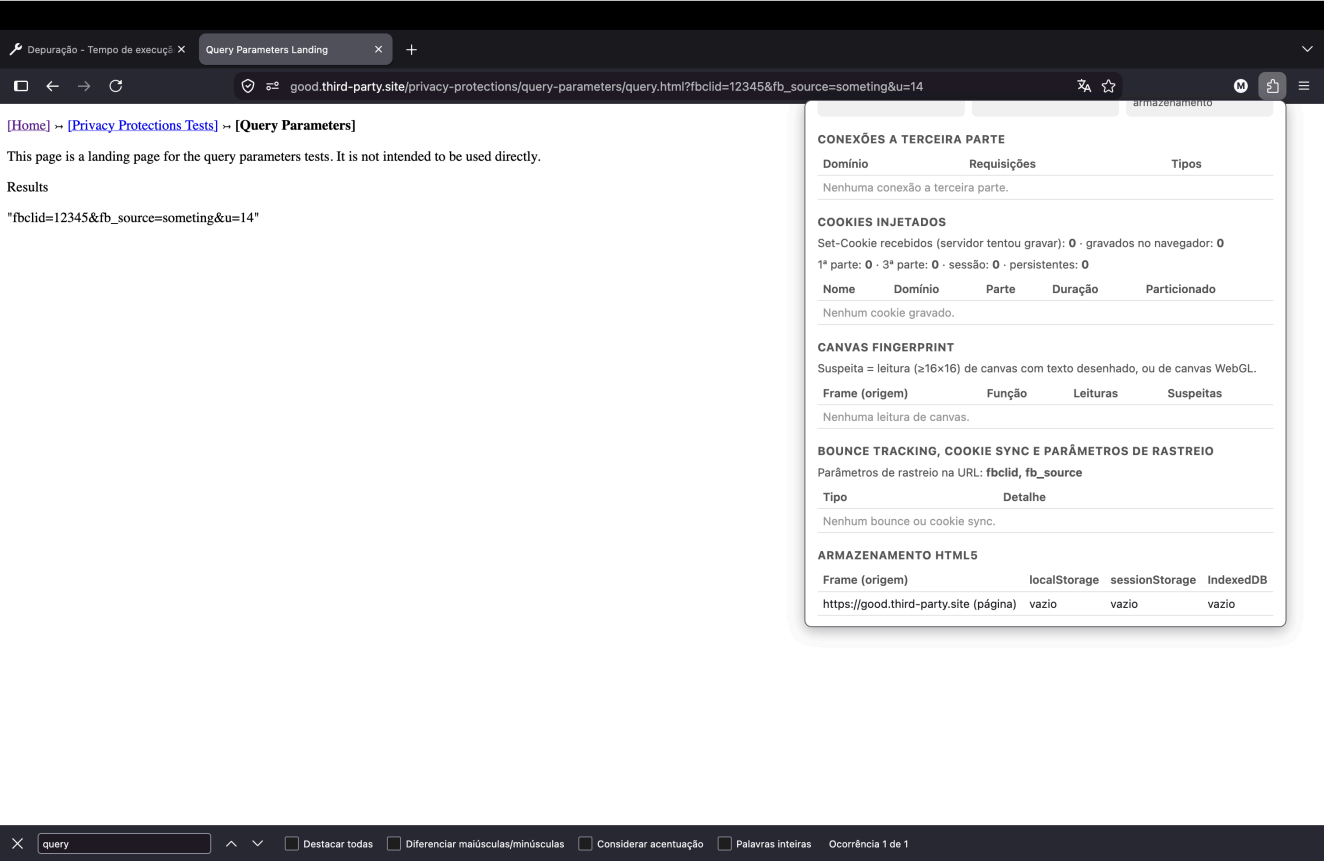


Figura 21. Query parameters, terceiro link: landing em good.third-party.site com fbclid, fb_source e u

4. Entregável 3: análise de 3 sites reais

Os sites foram de escolha livre. Foram escolhidos pt.wikipedia.org e duckduckgo.com, dois sites em que se esperava pouco ou nenhum rastreamento, para servir de contraste, e www.gov.br/pt-br, que carrega Google Tag Manager e outros serviços.

O procedimento foi o mesmo nos três sites: dados do site limpos, página inicial aberta sem login com a extensão carregada e o uBlock desligado, espera até a página estabilizar, prints do popup e exportação do HAR pela aba Rede do DevTools ("Salvar tudo como HAR"). Só depois o uBlock Origin foi ligado, a página recarregada e capturados o painel dele e o registrador (a tela do uBlock que lista requisição por requisição, filtrada pelas bloqueadas), que diz exatamente qual requisição cada regra bloqueou. O relatório do Blacklight (themarkup.org/blacklight) foi gerado no site deles. Nenhum aviso de cookies foi aceito ou recusado: a medida é o que o site faz antes do consentimento, que é também o que o Blacklight mede, já que ele não interage com a página. Os arquivos estão em evidencias/sites/<site>/.

Uma diferença de método que vale deixar clara antes das tabelas: o Blacklight e o uBlock trabalham com listas de rastreadores conhecidos e por isso rotulam o que encontram. O plugin conta todo domínio de terceira parte, inclusive CDN e serviço que não rastreia, sem rótulo. Então o plugin sempre lista mais domínios, e a reconciliação abaixo diz o que cada um é.

4.1 pt.wikipedia.org

Prints deste site: figuras 22, 23, 24, 25, 26.

Fonte	O que encontrou
Plugin	Nota 68 (moderada). 1 domínio de terceira parte, wikimedia.org (intake-analytics, thumb, meta, auth e upload; 12 requisições de tipo beacon, imageset, image e script). Cookies: 26 Set-Cookie recebidos e 12 gravados, sendo 1 de primeira parte e 11 de terceira, 2 de sessão e 10 persistentes (WMF-Uniq por 364 dias, WMF-Last-Access por 32 dias, NetworkProbeLimit por 0 dias, GeoIP de sessão), marcados como particionados. Nenhuma origem de terceira parte com armazenamento HTML5, nenhuma leitura de canvases, nenhum bounce, cookie sync ou parâmetro de rastreo.
Blacklight	0 ad trackers. 4 third-party cookies (acima da média de 3). Sem canvases fingerprinting, session recording, key logging, pixel do Facebook, TikTok ou X, e sem Google Analytics remarketing.
uBlock Origin	1 bloqueio na página (3%), 2 de 2 domínios conectados. O registrador mostra qual: POST intake-analytics.wikimedia.org/v1/events?hasty=true, tipo beacon, bloqueado pela regra intake-analytics.wikimedia.org^.
HAR	wikipedia.har: 38 requisições, 22 para pt.wikipedia.org, 13 para *.wikimedia.org (thumb 5, intake-analytics 4, meta 2, auth 1, upload 1) e 3 URIs data:. O HAR foi exportado logo depois dos prints (a aba Rede mostra 35 e 37 requisições nos dois prints; o HAR tem 38). Set-Cookie: 31 no HAR contra 26 no popup. Os 26 de *.wikimedia.org (thumb 15, meta 4, auth 3, intake-analytics 3, upload 1) coincidem com o popup; os 5 restantes vêm de uma única resposta de pt.wikipedia.org/w/load.php (GeoIP, NetworkProbeLimit, WMF-Last-Access, WMF-Last-Access-Global, WMF-Uniq) e não entraram na contagem do plugin. Desses 5, o popup registrou 1 cookie gravado de primeira parte. O HAR mostra também que a primeira requisição já enviava esses 5 cookies, ou seja, a limpeza de dados não foi feita antes desta visita, e 4 deles voltaram com o mesmo valor (WMF-Uniq voltou com valor novo). A causa de o plugin ter perdido essa resposta não foi identificada; os números de terceira parte, que são os que descontam, não são afetados.

Reconciliação:

Domínio ou item	Plugin	Blacklight	uBlock	Explicação técnica
Cookies de terceira parte	11	4	—	O plugin conta cada par nome e host: NetworkProbeLimit aparece em thumb, meta e auth; WMF-Last-Access em meta e auth; WMF-Uniq em vários hosts. Agrupando por nome, o HAR tem exatamente 4 cookies distintos vindos de *.wikimedia.org: GeoIP, NetworkProbeLimit, WMF-Last-Access e WMF-Uniq. São os mesmos 4 do Blacklight. As duas ferramentas medem a mesma coisa com granularidade diferente. Esses cookies são da própria Wikimedia Foundation, mas wikimedia.org e wikipedia.org são eTLD+1 diferentes, e o plugin usa a mesma regra do navegador.
wikimedia.org como terceiro	1 domínio (-2)	0 ad trackers	1 bloqueio	O plugin conta o domínio sem rotular. O Blacklight só conta domínios que estão na lista de rastreadores de anúncio dele, e wikimedia.org não está. O uBlock bloqueou uma única requisição, a telemetria POST intake-analytics.wikimedia.org/v1/events (regra intake-analytics.wikimedia.org^; a mesma requisição aparece 4 vezes no HAR sem uBlock), e deixou passar as imagens e scripts do mesmo domínio. As três concordam no fato, um único terceiro de telemetria e CDN, e divergem só no rótulo.
NetworkProbeLimit "persistente (0 dias)"	3 persistentes	—	—	O cookie chega com Max-Age=3600, uma hora. O plugin classifica como persistente qualquer cookie que tenha data de expiração. Está tecnicamente certo, mas infla o critério 3 em 3 pontos. O caso está na seção 6.
Canvas, storage de terceiros, bounce e sync	0	não encontrado	—	Concordam. O HAR não tem requisição a domínio de anúncio nem redirecionamento entre sites.

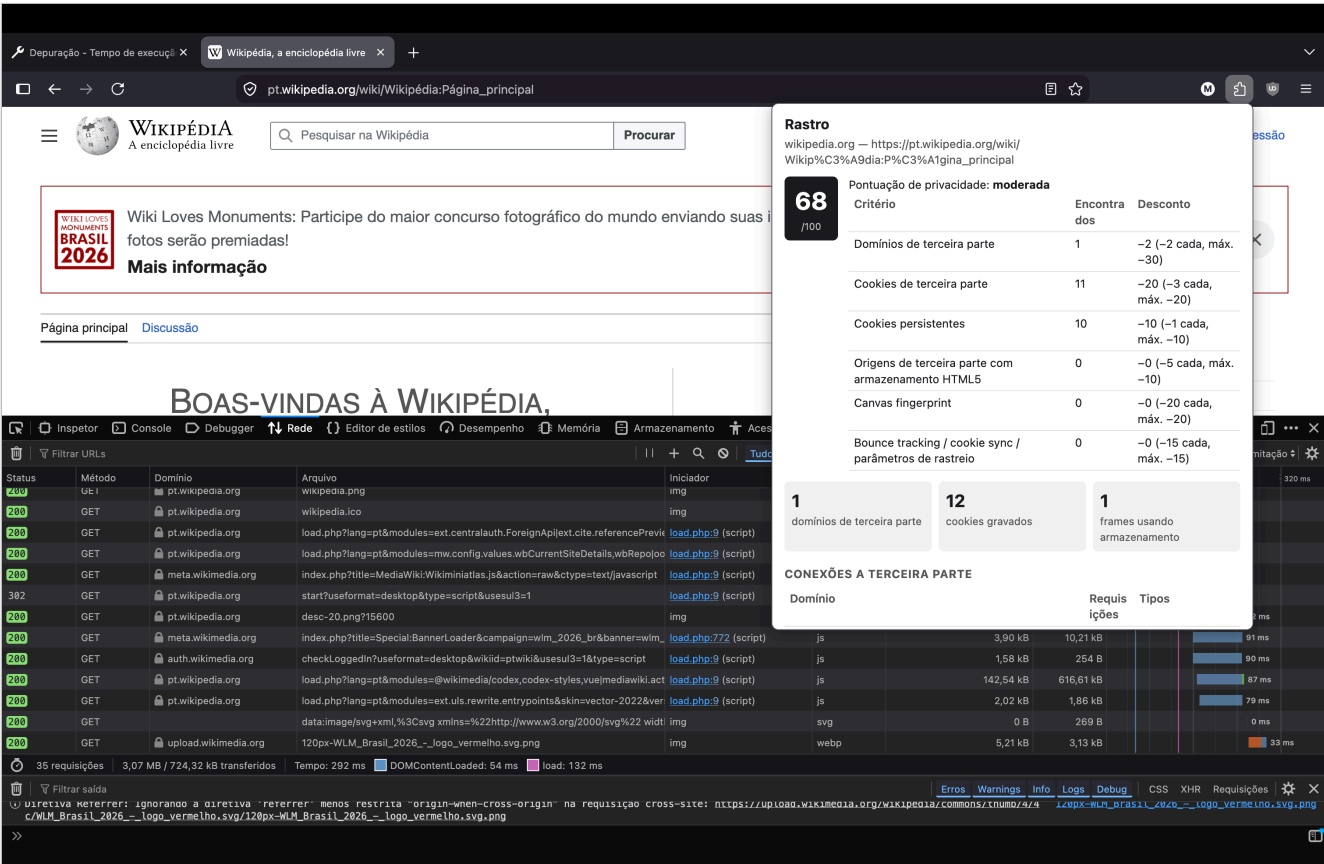


Figura 22. Wikipédia, popup do plugin com a nota e os critérios

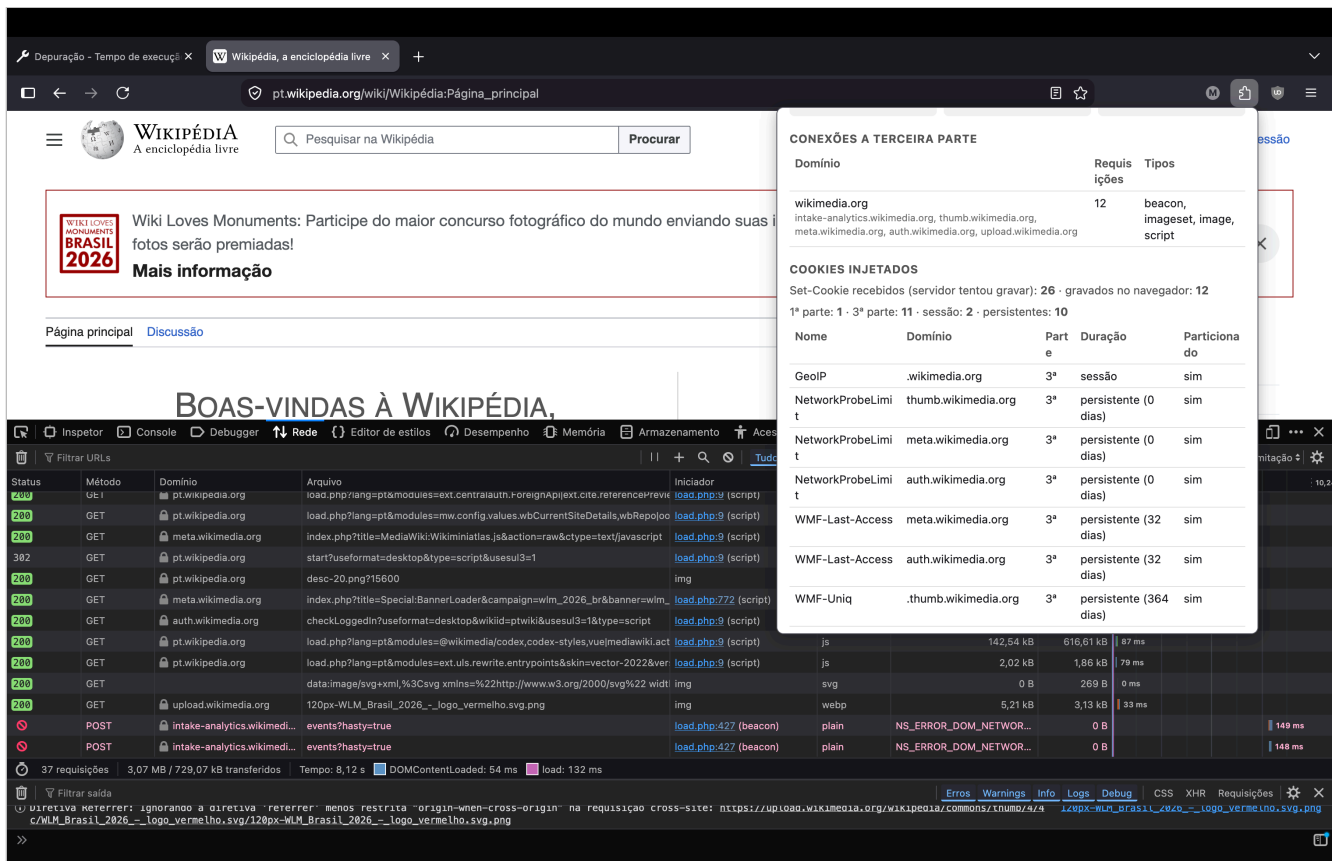


Figura 23. Wikipédia, terceiros e cookies injetados. Os dois POST a intake-analytics com NS_ERROR_DOM_NETWORK na aba Rede são falhas do próprio beacon, não bloqueio: no HAR as quatro requisições a esse host respondem 202.

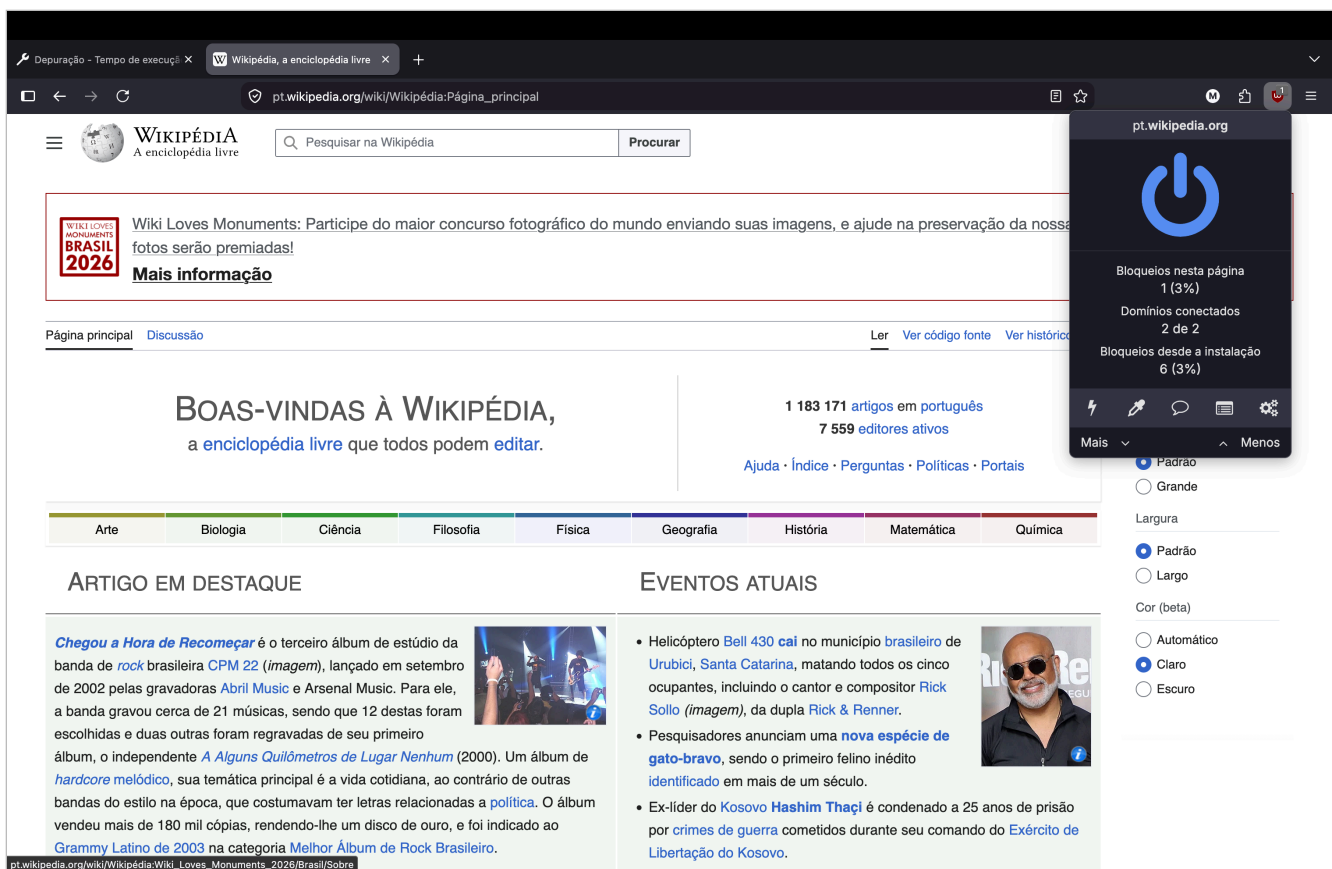


Figura 24. Wikipédia, uBlock Origin

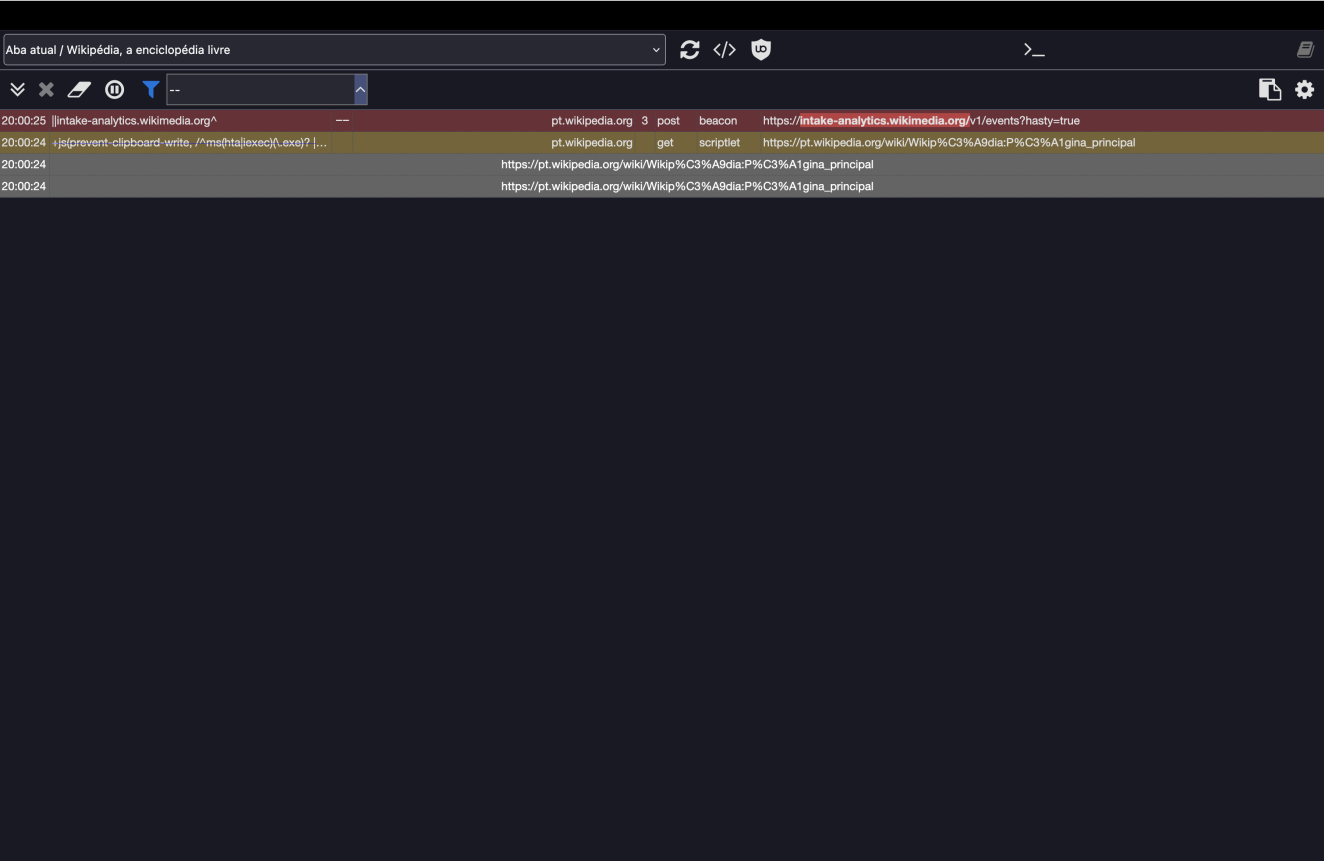


Figura 25. Wikipédia, registrador do uBlock filtrado pelas requisições bloqueadas

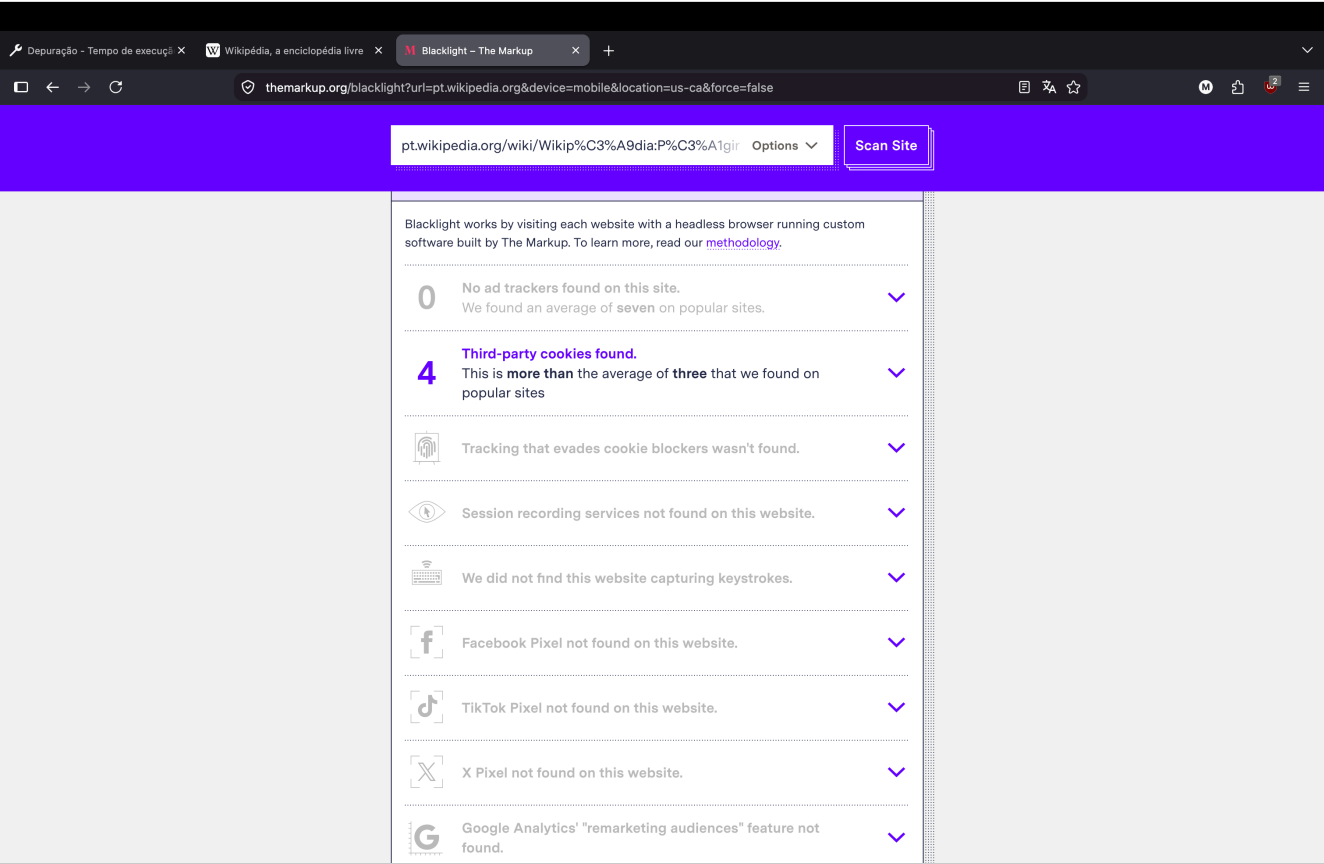


Figura 26. Wikipédia, Blacklight

4.2 www.gov.br/pt-br

Prints deste site: figuras 27, 28, 29, 30, 31, 32, 33, 34.

O aviso de cookies ficou sem resposta o tempo todo. A nota do plugin foi caindo enquanto a página carregava: 80 logo depois do `load`, 63 um pouco depois e 55 depois de uns 30 segundos (valores lidos no popup durante o carregamento; os prints são do estado final), porque o Google Tag Manager, o Google Analytics e o mPulse só disparam quando a página já está pronta. Os prints e o HAR são do estado estabilizado, com nota 55.

Fonte	O que encontrou
Plugin	Nota 55 (moderada). 11 domínios de terceira parte: <code>ebc.com.br</code> com 12 requisições (iframe da Agência Gov), <code>cloudflare.com</code> 11 (cdnjs), <code>sistema.gov.br</code> 10 (barra do gov.br), <code>go-mpulse.net</code> 4, <code>vlbras.gov.br</code> 3, <code>jsdelivr.net</code> 3, <code>googletagmanager.com</code> 2, <code>google.com</code> 2 (analytics), <code>browser-update.org</code> 1, <code>doubleclick.net</code> 1 (beacon) e <code>google.com.br</code> 1 (image). Cookies: 89 <code>Set-Cookie</code> recebidos e 4 gravados, 2 de primeira parte e de sessão (<code>TSceab889027</code> , <code>Encrypted-Local-Storage-Key</code>) e 2 de terceira parte persistentes por 400 dias (<code>_ga</code> e <code>_ga_X0DQ0CT40G</code> em <code>.ebc.com.br</code> , particionados). Nenhum storage HTML5 de terceiros e nenhum canvas. Cookie sync detectado (-15). O popup lista o identificador de cliente do GA, <code>cid=72351855...</code> , enviado a <code>google.com</code> , <code>doubleclick.net</code> e <code>google.com.br</code> , e também os parâmetros <code>tid</code> , <code>gtm</code> , <code>gcd</code> e <code>tag_exp</code> enviados aos mesmos domínios e a <code>googletagmanager.com</code> .
Blacklight	1 ad tracker, que o próprio Blacklight descreve como "a script belonging to the company Alphabet, Inc." (figura 34). 0 third-party cookies. Sem canvas fingerprinting, session recording, key logging e pixels. "Google Analytics remarketing audiences" não encontrado. A visita do Blacklight foi feita com <code>device=mobile</code> e <code>location=us-ca</code> .
uBlock Origin	5 bloqueios na página (3%), 9 de 12 domínios conectados. O registrador lista os cinco: <code>s.go-mpulse.net/boomerang/R7WQE...</code> (2 vezes, regra <code> go-mpulse.net^</code>), <code>www.googletagmanager.com/gtag/js?id=G-X0DQ0CT40G</code> (2 vezes, regra <code> googletagmanager.com^</code>), e o uBlock ainda substitui o script por uma versão neutra, <code>googletagmanager_gtm.js</code> , via <code>redirect-rule</code> e <code>browser-update.org/update.min.js</code> (1 vez, regra <code> browser-update.org^\$3p</code>). Os quatro primeiros são pedidos pelo iframe <code>agenciagov.ebc.com.br</code> ; o último, pela própria página.
HAR	<code>gov.br.har</code> : 140 requisições. As de rastreamento: <code>www.googletagmanager.com/gtag/js?id=G-X0DQ0CT40G</code> (2 vezes), <code>analytics.google.com/g/collect?...</code> (2 vezes, HTTP 204), <code>stats.g.doubleclick.net/g/collect?...</code> (204), <code>www.google.com.br/ads/ga-audiences?...</code> (200, um GIF), <code>s.go-mpulse.net/boomerang/...</code> (2 vezes), <code>c.go-mpulse.net/api/config.json?...d=agenciagov.ebc.com.br</code> (4 vezes) e <code>browser-update.org/update.min.js</code> . Os 89 <code>Set-Cookie</code> de <code>www.gov.br</code> são o mesmo cookie de sessão <code>TSceab889027</code> (nome no padrão dos balanceadores F5 BIG-IP), regravado com valor diferente em cada uma das 89 respostas. As contagens por domínio do popup e do HAR diferem um pouco (<code>ebc.com.br</code> 12 no popup e 10 no HAR; <code>go-mpulse.net</code> 4 e 6; 138 requisições na aba Rede do print e 140 no HAR) porque são contadores diferentes tirados em momentos próximos: o popup conta eventos do <code>webRequest</code> da aba, o HAR é a exportação do DevTools feita logo depois. O conjunto dos 11 domínios de terceira parte é o mesmo nos dois, e é esse conjunto que entra na nota. Não existe <code>Set-Cookie</code> para o <code>_ga</code> : ele é criado por JavaScript (<code>gtag.js</code>) dentro do iframe da EBC.

Reconciliação:

Domínio ou item	Plugin	Blacklight	uBlock	Explicação técnica
Domínios de terceira parte	11	1 ad tracker	12 conectados, 5 bloqueados	São três critérios diferentes. O plugin conta eTLD+1 distintos do site visitado, o que inclui as CDNs (<code>cloudflare.com</code> , <code>jsdelivr.net</code>), o iframe da EBC e até <code>sistema.gov.br</code> e <code>vlbras.gov.br</code> : como <code>gov.br</code> está na Public Suffix List, cada órgão é um site diferente para o navegador, e o plugin segue a mesma regra. O uBlock conta hostnames, por isso 12, e bloqueou 5 requisições de 3 domínios: mPulse, Google Tag Manager e browser-update. As requisições a <code>analytics.google.com</code> , <code>stats.g.doubleclick.net</code> e <code>google.com.br/ads/ga-audiences</code> não aparecem no registrador porque o <code>gtag.js</code> é bloqueado antes de rodar, e é ele quem as dispara: com o uBlock ligado, elas nem acontecem. O Blacklight só rotula o que está na lista de rastreadores de anúncio dele, e identifica o 1 ad tracker como um script da Alphabet (Google). No HAR, o único script da Alphabet é o <code>gtag.js</code> de <code>www.googletagmanager.com</code> ; as demais requisições ao Google são POST de coleta e uma imagem, não scripts.
<code>_ga</code> e <code>_ga_X0DQ0CT40G</code> (<code>.ebc.com.br</code>)	2 cookies de terceira parte, 400 dias	0 third-party cookies	—	O HAR mostra que esses cookies não vêm de cabeçalho <code>Set-Cookie</code> : são gravados pelo <code>gtag.js</code> via <code>document.cookie</code> dentro do iframe <code>agenciagov.ebc.com.br/embedgov_view</code> . Para o iframe eles são de primeira parte; para a aba, que está em <code>www.gov.br</code> , são de terceira parte, e o Firefox os particiona. O plugin classifica em relação à aba, como o enunciado pede. A explicação mais consistente com o HAR para o 0 do Blacklight é a visita em modo mobile: o <code>_ga</code> só existe porque o iframe da Agência Gov carrega o <code>gtag.js</code> , e num layout sem esse embed o cookie não é criado.
Cookie sync (critério 6)	detectado (-15)	—	—	O HAR confirma: o ID de cliente do GA, <code>cid=1372646340.1790629402</code> , que é o identificador guardado no cookie <code>_ga</code> (formato <code>GA1.1.<cid></code>), vai para <code>stats.g.doubleclick.net</code> e para <code>www.google.com.br/ads/ga-audiences</code> . O mesmo identificador cruza três domínios. O popup mostra a mesma coisa (figura 30): <code>cid=72351855...</code> enviado a <code>google.com</code> , <code>doubleclick.net</code> e <code>google.com.br</code> . O valor é outro porque a figura 30 é de uma visita nova, com os dados do site limpos, e o GA gera um <code>cid</code> novo a cada cookie <code>_ga</code> criado. O Blacklight não tem essa categoria. Um detalhe que precisa de ajuste: além do <code>cid</code> , o popup lista <code>tid</code> , <code>gtm</code> , <code>gcd</code> e <code>tag_exp</code> como se fossem identificadores. São parâmetros de configuração do GA, iguais para todos os visitantes. A heurística acerta o caso por causa do <code>cid</code> , mas gera linhas a mais (seção 6).
Google Analytics remarketing (<code>ga-audiences</code>)	requisição contada em <code>google.com.br</code>	"não encontrado"	não ocorre: o <code>gtag.js</code> que a dispara é bloqueado antes	O HAR tem <code>GET www.google.com.br/ads/ga-audiences?...</code> com status 200, que é o tipo de requisição que o Blacklight descreve como "remarketing audiences". Pelo mesmo motivo do <code>_ga</code> , a visita mobile do Blacklight, sem o iframe que carrega o GA, não gera essa requisição. O plugin não rotula a requisição como remarketing, só conta o domínio.

go-mpulse.net (Akamai mPulse)	4 requisições (-2)	—	bloqueado (go-mpulse.net^)	É monitoramento de desempenho (RUM) carregado pelo iframe da EBC, dá para ver pelo d=agenciagov.ebc.com.br na URL. Está nas listas do uBlock, por isso ele bloqueia. Não é rastreador de anúncio, por isso o Blacklight ignora. O plugin trata como qualquer outro terceiro.
Canvas	0	não encontrado	—	Concordam.

[illegible]

Figura 27. gov.br, popup do plugin com a nota e os critérios

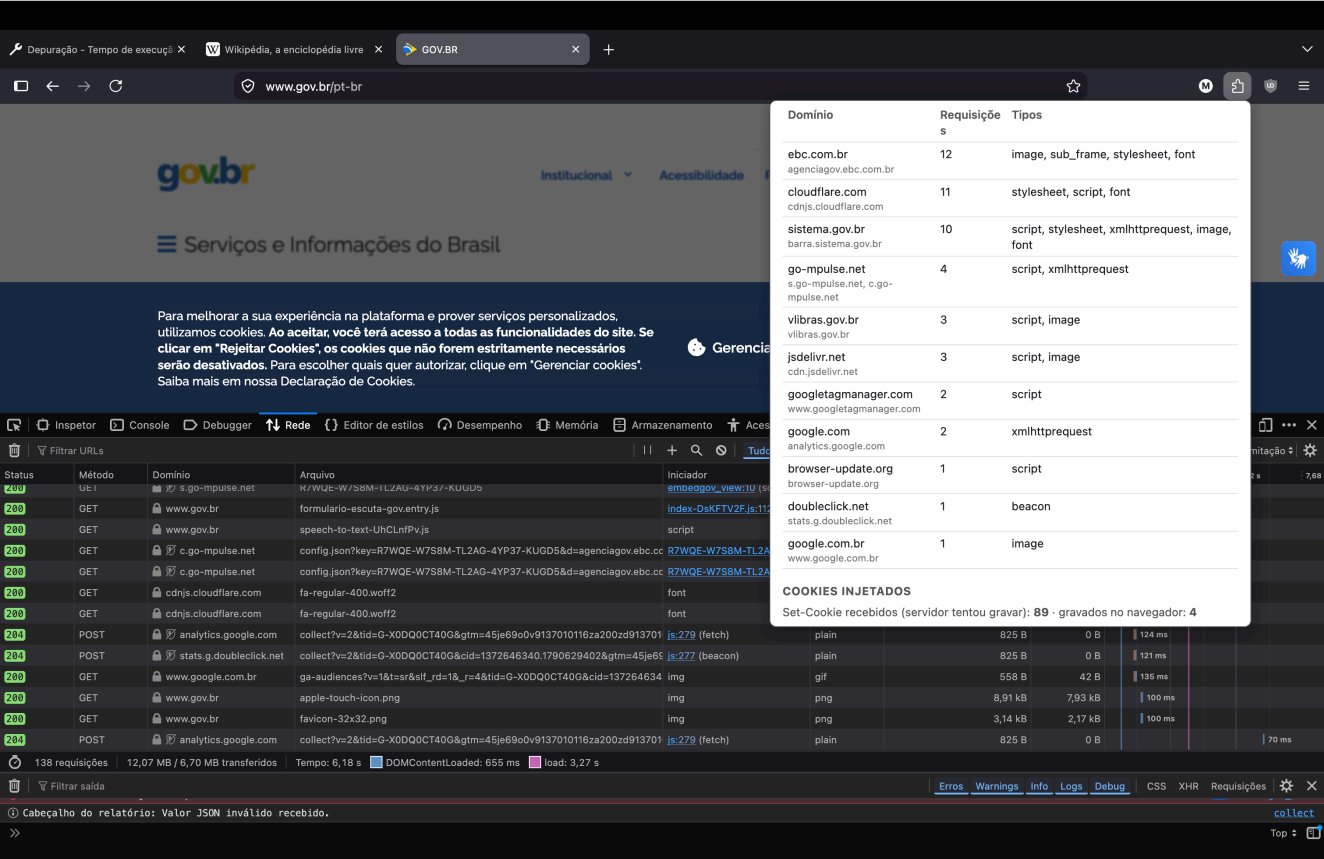


Figura 28. gov.br, os 11 domínios de terceira parte

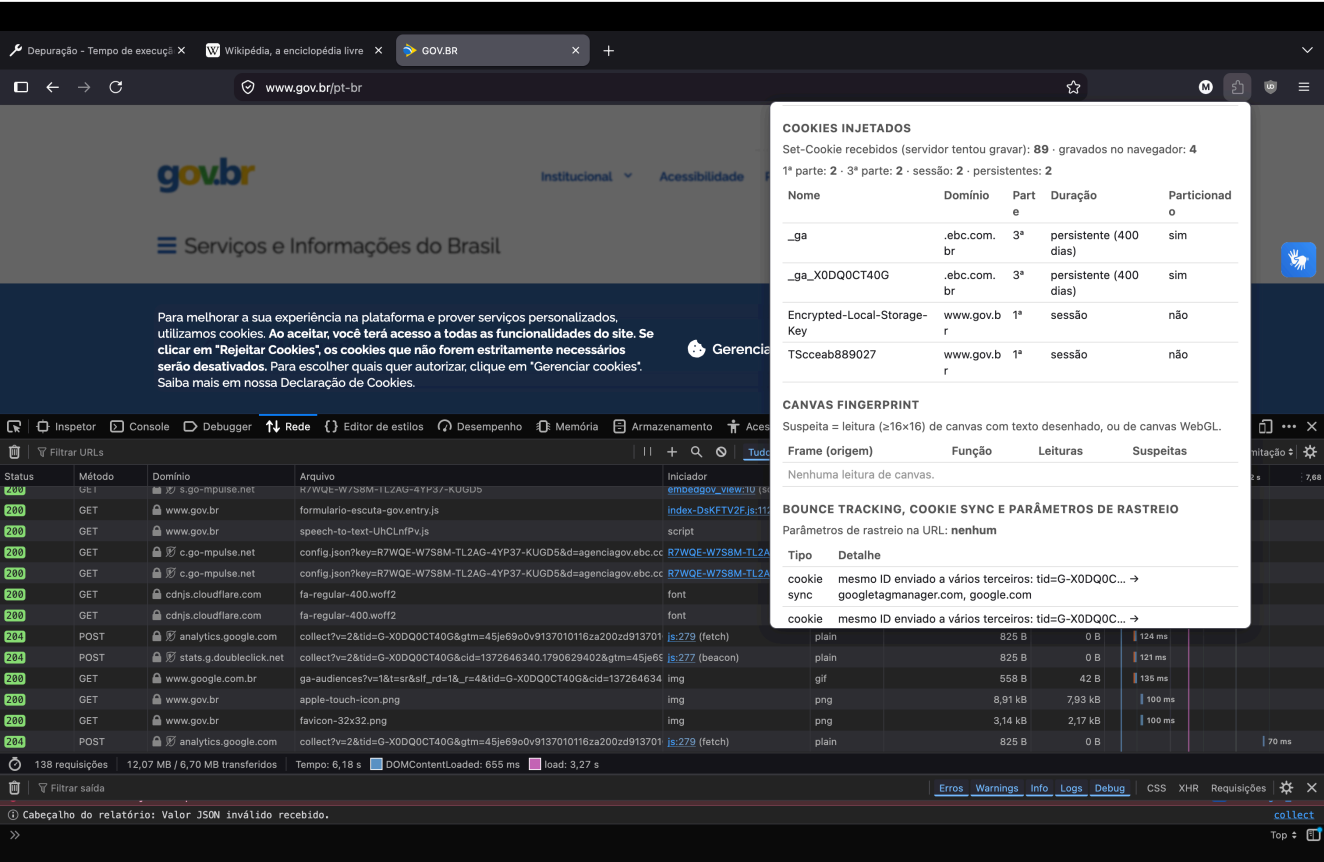


Figura 29. gov.br, cookies, canvas e cookie sync

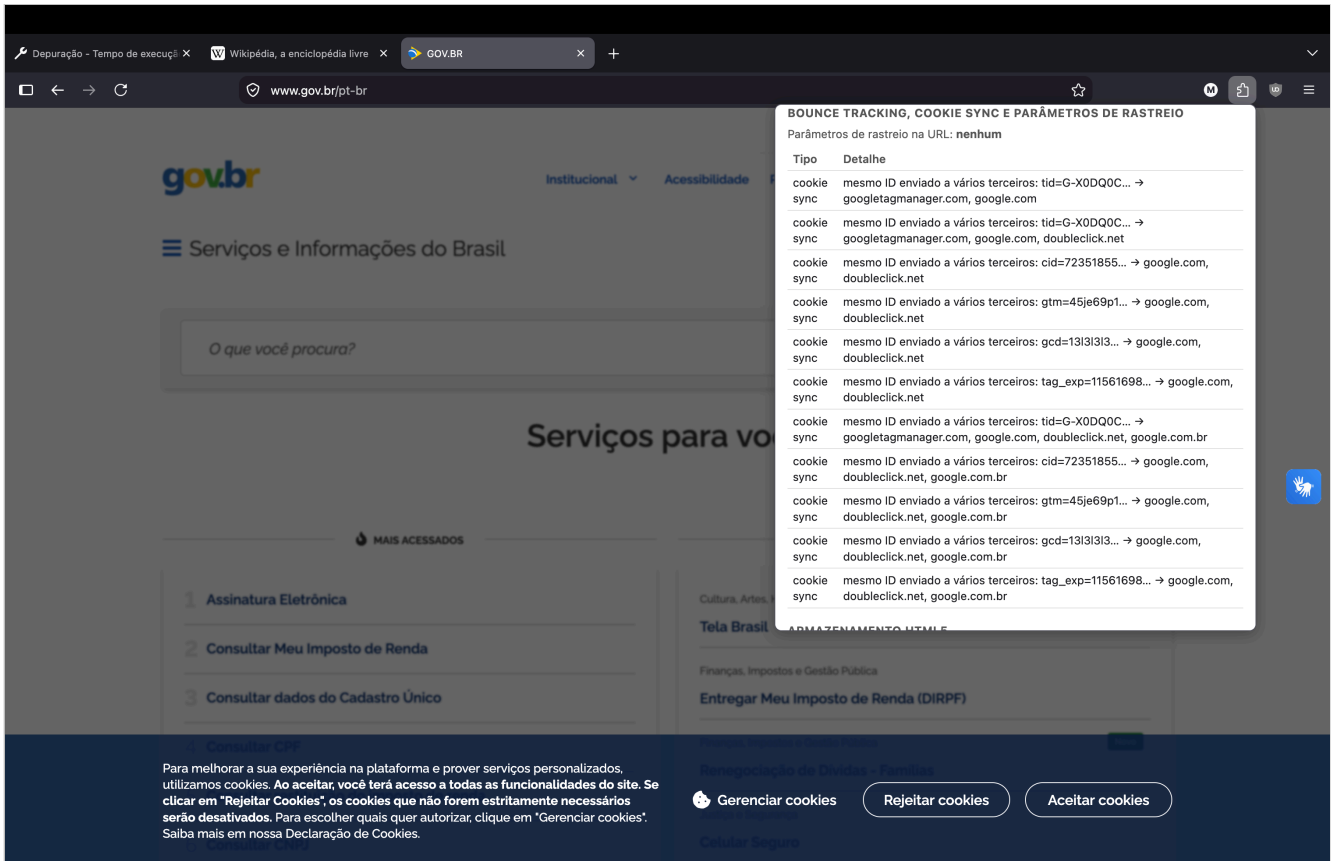


Figura 30. gov.br, seção de cookie sync completa (visita nova, com dados do site limpos)

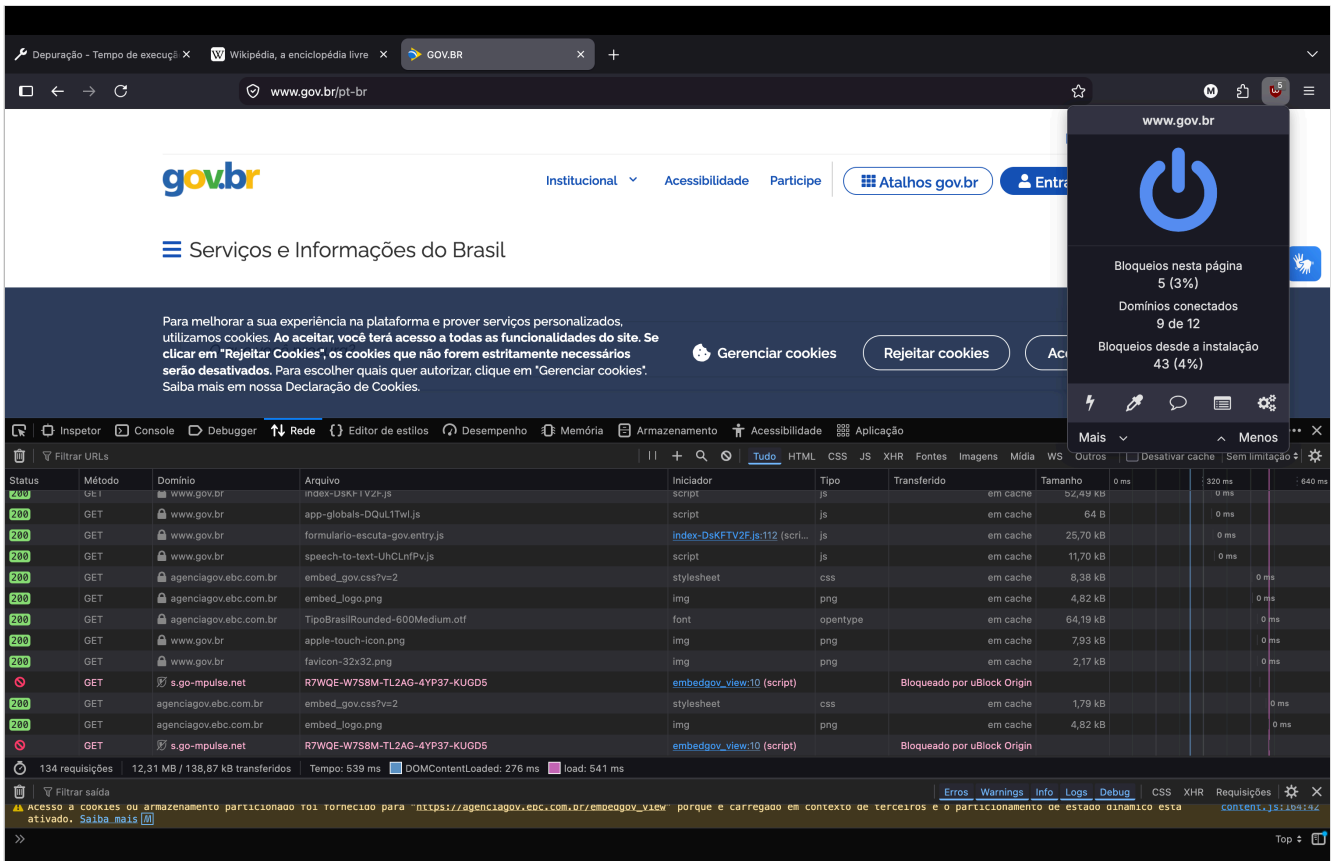


Figura 31. gov.br, uBlock Origin com 5 bloqueios

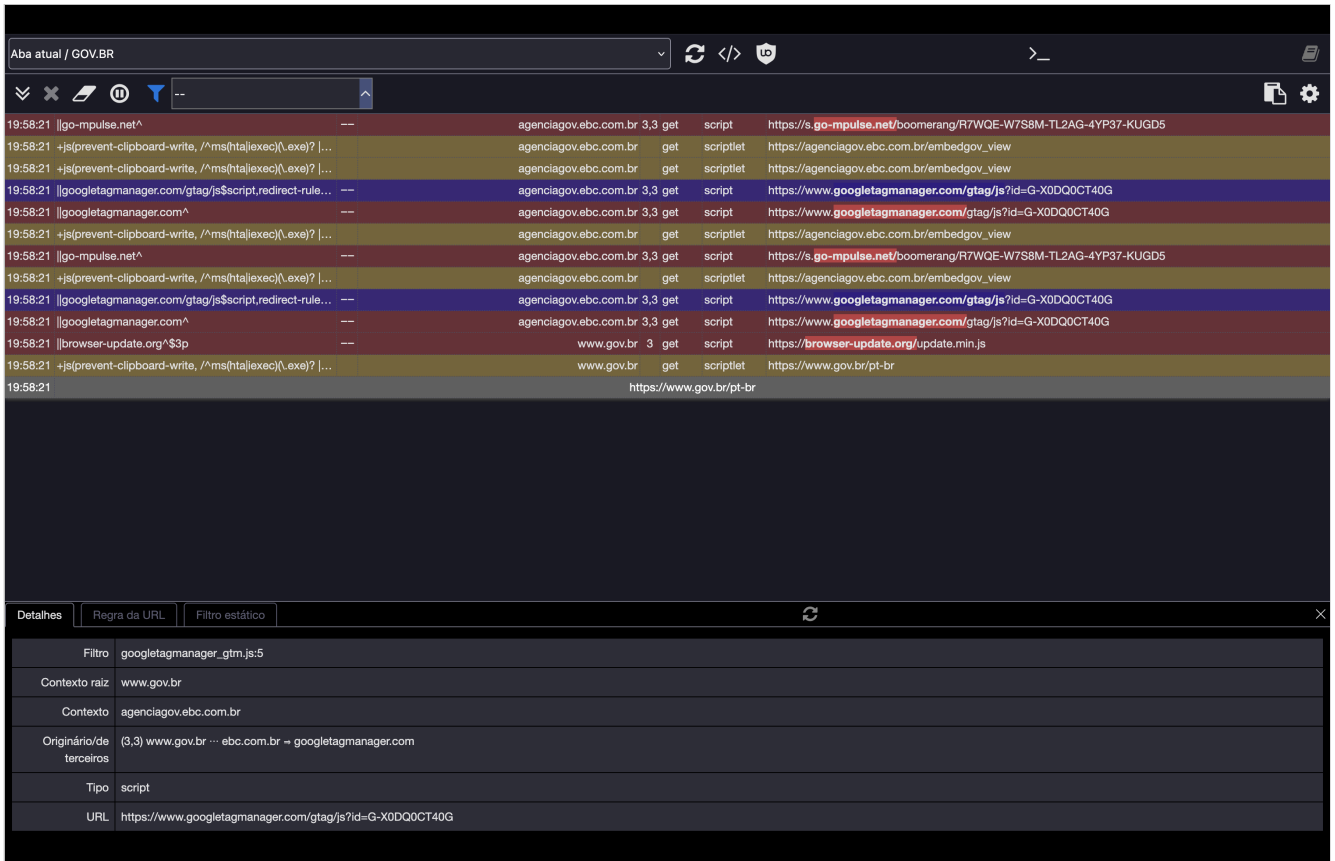


Figura 32. gov.br, registrador do uBlock filtrado pelas requisições bloqueadas

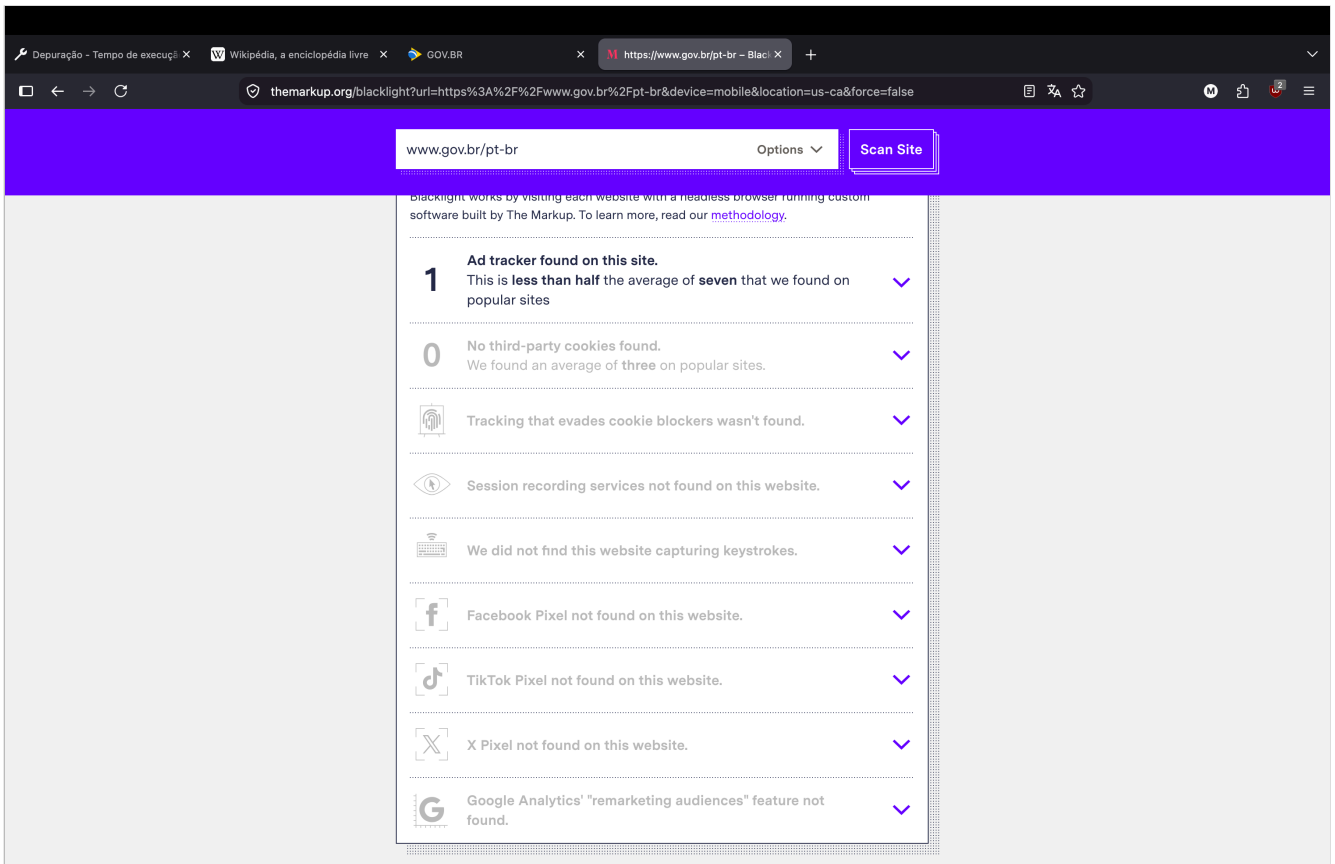


Figura 33. gov.br, Blacklight

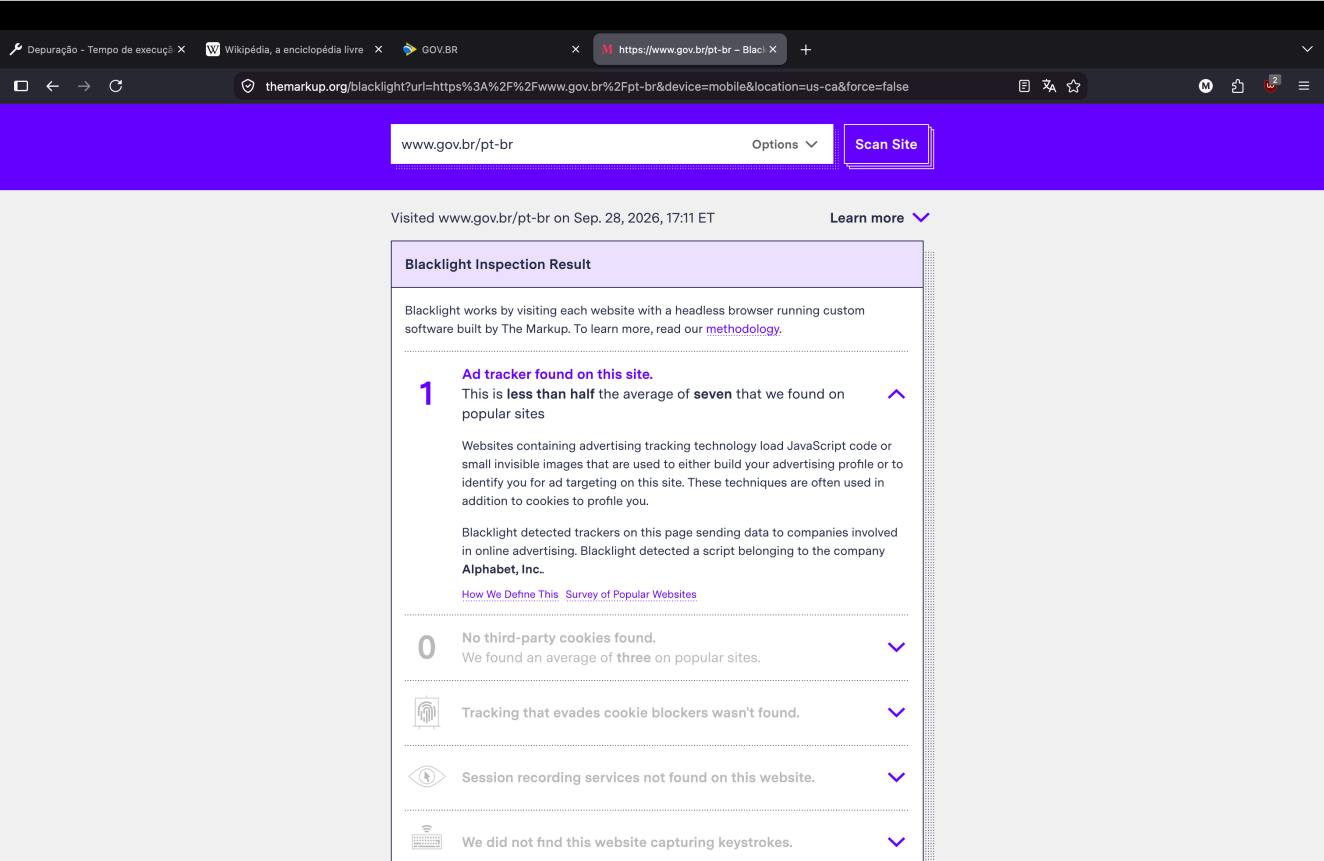


Figura 34. gov.br, Blacklight com a linha do ad tracker expandida (script da Alphabet, Inc.)

4.3 duckduckgo.com

Prints deste site: figuras 35, 36, 37, 38, 39.

Fonte	O que encontrou
Plugin	Nota 100 (boa). Nenhum domínio de terceira parte, nenhum Set-Cookie recebido, nenhum cookie gravado, nenhuma origem de terceiros com armazenamento HTML5 (o próprio duckduckgo.com está com localStorage, sessionStorage e IndexedDB vazios), nenhuma leitura de canvases, nenhum bounce, cookie sync ou parâmetro de rastreamento.
Blacklight	0 ad trackers, 0 third-party cookies, e nada nas outras categorias.
uBlock Origin	8 bloqueios na página (10%), 1 de 1 domínio conectado. O registrador mostra que todos são POST improving.duckduckgo.com/t/... (page_home_impression, static_webvitals, static_fcp, static_hydrated, atb_home_impression, wide_event_homepage_load-homepage e outros), tipo beacon, bloqueados pela regra duckduckgo.com/t/ e marcados pelo próprio uBlock como primeira parte.
HAR	duckduckgo.har: 73 requisições, 63 para duckduckgo.com e 10 para improving.duckduckgo.com (POST /t/page_home_impression, /t/static_webvitals, /t/static_fcp, /t/atb_home_impression, /t/wide_event_homepage_load-homepage, /e e outros). Nenhuma resposta traz Set-Cookie, nenhuma requisição envia cookie, e não há host fora de duckduckgo.com.

Reconciliação:

Domínio ou item	Plugin	Blacklight	uBlock	Explicação técnica
improving.duckduckgo.com (telemetria)	não contado, é primeira parte	não contado	8 bloqueios	É a única divergência do site. As 10 requisições POST improving.duckduckgo.com/t/... do HAR são métricas de uso da página (impressão da home, Web Vitals, FCP, variante atb=v553-6), sem cookie e para o mesmo eTLD+1 da página. O plugin, como foi pedido, mede terceira parte e cookies, e uma telemetria de primeira parte sem identificador não pontua. O Blacklight também só olha terceiros. O uBlock bloqueia pela regra duckduckgo.com/t/, que pega o caminho /t/ mesmo sendo do próprio site; o registrador confirma que todos os bloqueios são esses POST. Isso mostra um limite da abordagem por terceira parte: ela não pega coleta feita pelo próprio site.
Todos os outros critérios	0	não encontrado	—	Concordam. É o site de contraste: a metodologia dá 100 para um site que não usa terceiros nem cookies.

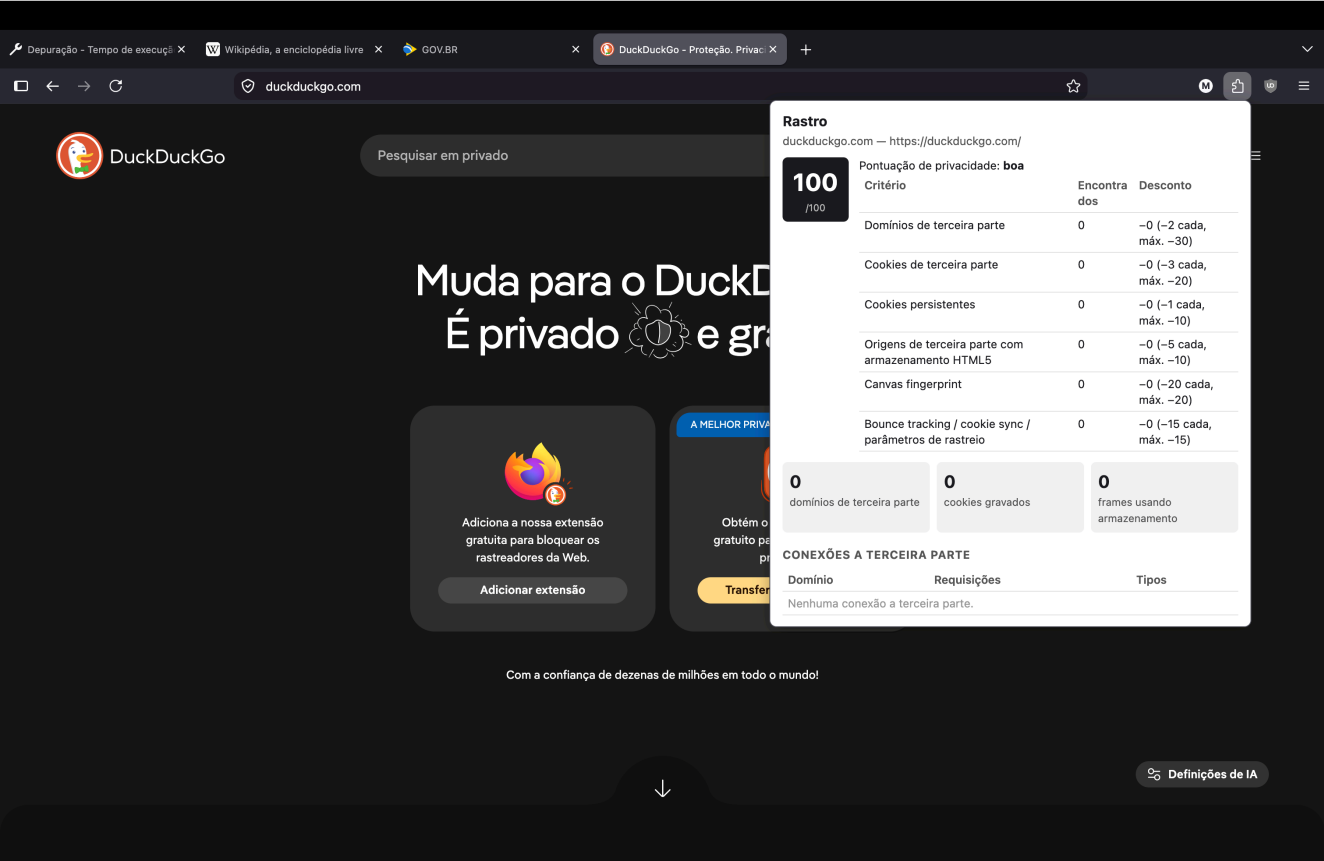


Figura 35. DuckDuckGo, popup do plugin com nota 100

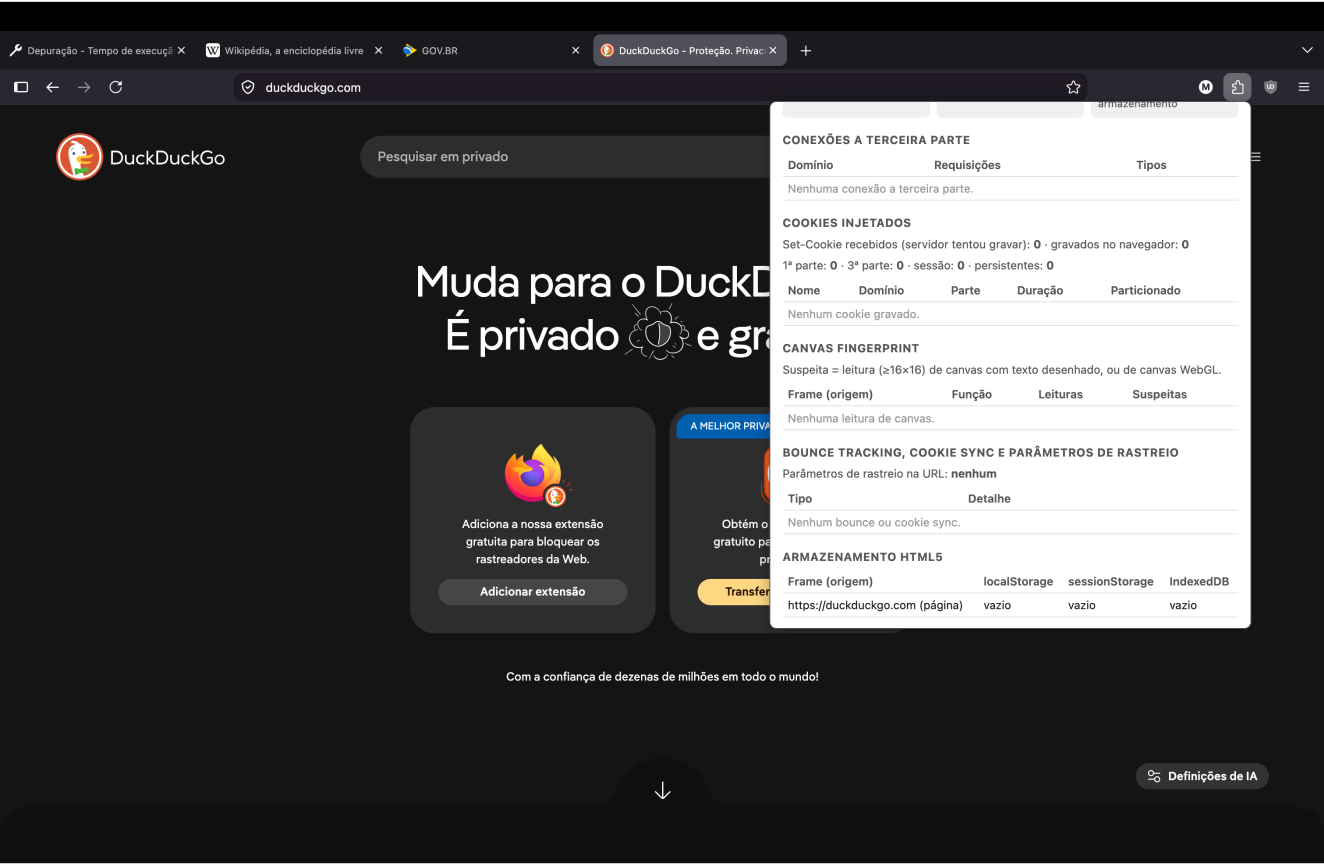


Figura 36. DuckDuckGo, cookies, canvas, bounce e armazenamento vazios

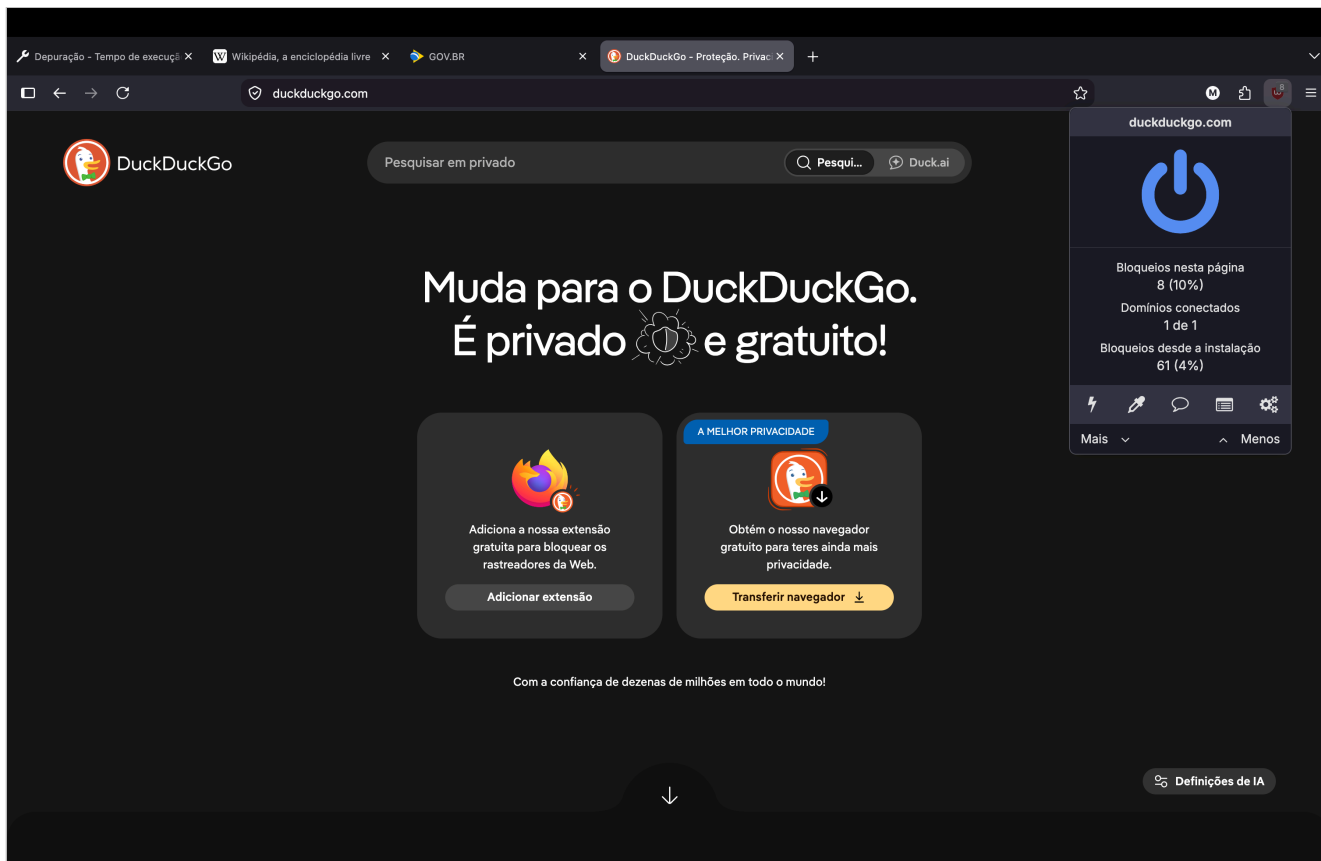


Figura 37. DuckDuckGo, uBlock Origin com 8 bloqueios de telemetria de primeira parte

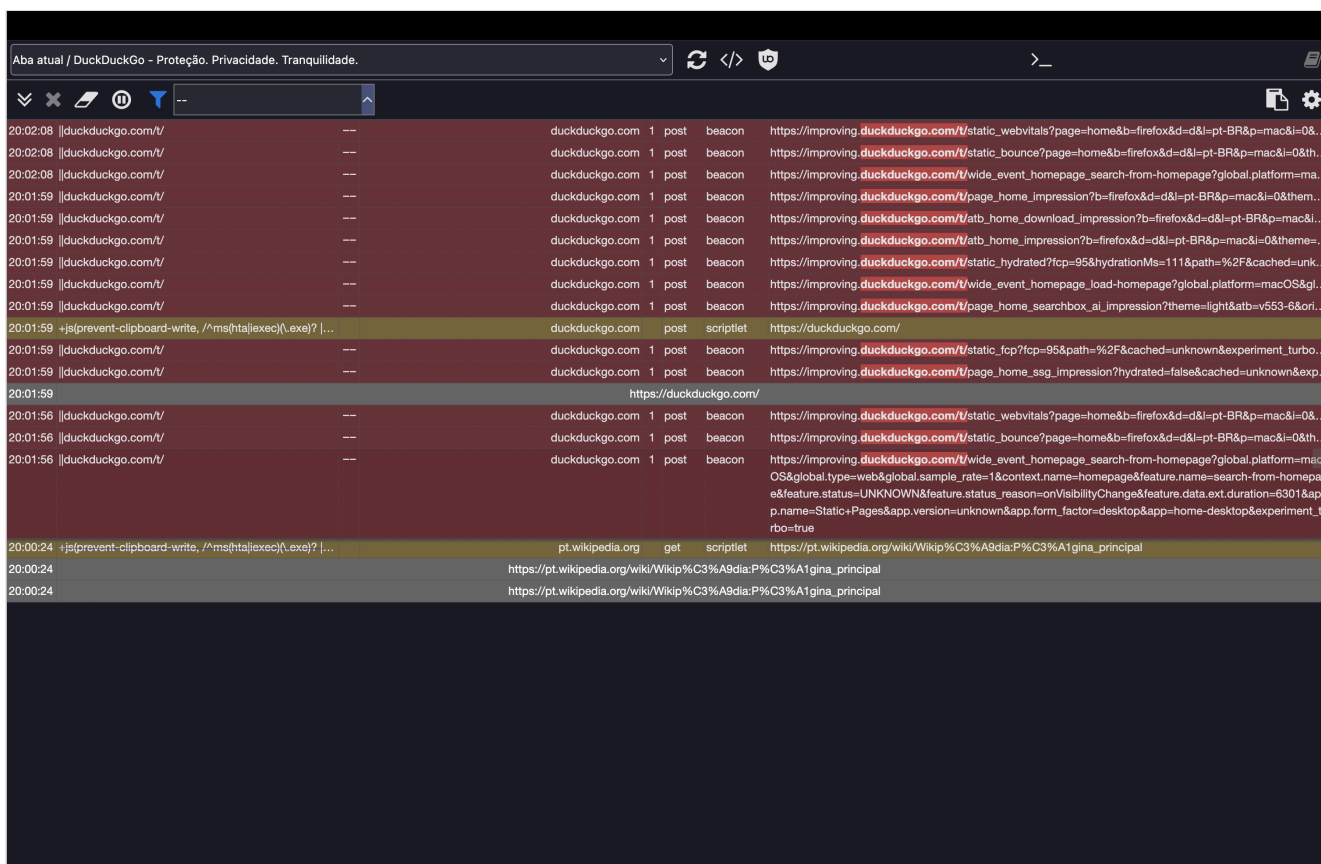


Figura 38. DuckDuckGo, registrador do uBlock filtrado pelas requisições bloqueadas

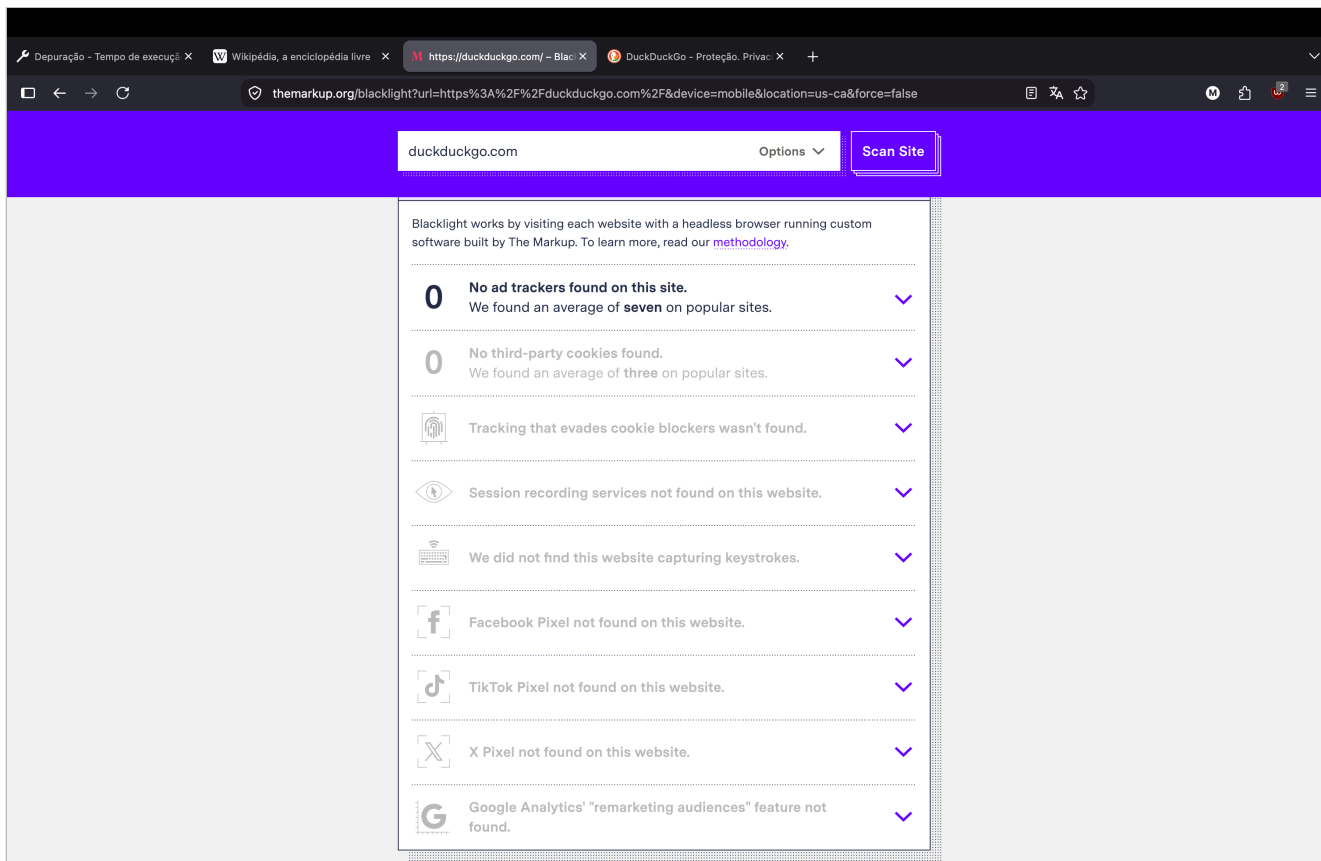


Figura 39. DuckDuckGo, Blacklight

5. Entregável 4: pontuação de privacidade

5.1 Metodologia

A página começa com 100 pontos e perde pontos a cada ocorrência de cada critério, até um teto por critério, para que um único tipo de problema não zere a nota. A nota mínima é 0. Faixas: 80 a 100 é boa, 50 a 79 é moderada, abaixo de 50 é ruim. Cada critério corresponde a um item que o enunciado manda detectar. O princípio dos pesos é: quanto mais difícil for para o usuário se defender, maior o peso. Um cookie dá para apagar; um fingerprint não depende de nada gravado. O cálculo está em `lib/score.js`.

Critério	Desconto	Teto	Justificativa
Domínio de terceira parte	-2 cada	-30	Cada terceiro recebe IP, navegador e a página visitada (Referer). Peso baixo por item porque muitos terceiros são CDN; teto alto porque dezenas de terceiros indicam um ecossistema de rastreamento.
Cookie de terceira parte	-3 cada	-20	Permite ao terceiro reconhecer o usuário em sites diferentes.
Cookie persistente	-1 cada	-10	Sobrevive ao fechamento do navegador. Peso baixo porque cookie persistente também serve para preferência legítima.
Origem de terceira parte com armazenamento HTML5	-5 cada	-10	Outro lugar para guardar identificador, fora dos cookies e das ferramentas usuais de limpeza. Conta origens distintas.
Canvas fingerprint	-20	-20	Identifica o navegador sem gravar nada. Limpar cookies não resolve.
Bounce tracking, cookie sync e parâmetros de rastreio	-15	-15	Liga a identidade entre sites e contorna o particionamento de cookies do navegador.

5.2 Aplicação aos 3 sites e comparação com o Blacklight

O Blacklight não dá uma nota única, então a comparação é critério a critério. As equivalências usadas: third-party cookies do Blacklight com o critério 2; canvas fingerprinting com o critério 5; ad trackers com o critério 1, lembrando que o Blacklight conta só rastreadores conhecidos e o plugin conta todo terceiro.

Site	Nota do plugin	Critérios que descontaram	Blacklight	Onde concordam e onde divergem
pt.wikipedia.org	68 (moderada)	1 terceiro (-2); 11 cookies de terceira parte (-20, no teto); 10 persistentes (-10, no teto)	0 ad trackers, 4 third-party cookies, nada mais	Concordam em canvas, session recording e pixels (nada) e em haver cookies de terceira parte acima da média. Divergem na severidade: o plugin tira 30 pontos por cookies que são da própria Wikimedia, com nomes repetidos entre hosts, e o Blacklight conta 4 nomes e não os liga a anúncio. A nota 68 é dura para um site sem rastreador de anúncio, e o motivo é o critério 2 contar por nome e host.

www.gov.br-pt-br	55 (moderada)	11 terceiros (-22); 2 cookies de terceira parte (-6); 2 persistentes (-2); cookie sync (-15)	1 ad tracker, 0 third-party cookies, remarketing não encontrado	Concordam que existe rastreador de anúncio do Google antes do consentimento: o Blacklight aponta um script da Alphabet, e o plugin e o HAR mostram o <code>gtag.js</code> do Google Tag Manager, mais as coletas para <code>analytics.google.com</code> e <code>stats.g.doubleclick.net</code> . Divergem nos cookies (o <code>_ga</code> gravado por JS no iframe da EBC, que o Blacklight não viu) e no remarketing (o <code>ga-audiences</code> está no HAR e não apareceu na visita mobile do Blacklight). O critério 6 pega o que o Blacklight não mede: o <code>cid</code> do GA compartilhado com DoubleClick e Google Ads. Vale a ressalva da seção 6: a heurística também dispara com parâmetros fixos do GA4, então na prática qualquer site com GA4 recebe os -15; no gov.br o desconto é justificado pelo <code>cid</code> , mas o critério não distingue os dois casos. A nota é menor que a da Wikipédia, o que faz sentido, porque o rastreamento aqui é real.
duckduckgo.com	100 (boa)	nenhum	0 em tudo	Plugin e Blacklight concordam em tudo. Só o uBlock aponta algo, as 8 requisições de telemetria de primeira parte para <code>improving.duckduckgo.com</code> , que nenhum critério do plugin cobre porque não há terceiro nem cookie. A régua separa os três sites: 100 sem rastreamento, 68 com cookies de terceira parte da própria organização, 55 com Google Analytics, DoubleClick e cookie sync antes do consentimento.

6. Limitações conhecidas

- O eTLD+1 é aproximado: a lista de sufixos é reduzida (`bucket.s3.amazonaws.com` vira `amazonaws.com`) e agrupa `good` e `bad.third-party.site`.
- `cookies.onChanged` não diz de qual aba veio o cookie. A atribuição é por domínio, então duas abas abertas com o mesmo terceiro podem se confundir. Um cookie regravado com valor idêntico pode não gerar evento (observado no DDG; não está confirmado na documentação). Na Wikipédia (seção 4.1) uma resposta com 5 `Set-Cookie` de primeira parte resultou em 1 cookie contado, sem causa identificada.
- O armazenamento HTML5 é da origem, então o popup mostra também o que outras páginas do mesmo site gravaram antes.
- Canvas: a detecção é heurística (texto ou WebGL, mínimo 16×16). Leituras em workers e por `createImageBitmap` não são cobertas, e outros vetores de fingerprint (navigator, screen, fontes, áudio) não são monitorados.
- Bounce: a regra de tempo (menos de 10 segundos sem interação) pode acusar redirecionamentos legítimos, como um login único. O Firefox não sinalizou `client_redirect` em nenhum teste.
- Cookie com expiração muito curta (`NetworkProbeLimit`, com Max-Age de uma hora) conta como persistente e infla um pouco o critério 3.
- Cookie sync: a heurística compara valores de parâmetros entre terceiros e acerta o caso do gov.br pelo `cid`, mas também lista parâmetros de configuração que são iguais para todos os visitantes (`tid`, `gtm`, `gcd`, `tag_exp`) e repete a linha cada vez que um domínio novo entra. A melhoria seria ignorar parâmetros com valor igual entre visitantes e agrupar por identificador.
- A contagem de terceira parte não distingue CDN, órgão do mesmo governo (o `gov.br` está na Public Suffix List) e rastreador. Essa distinção foi feita neste relatório, comparando com as listas do Blacklight e do uBlock, e não no plugin.
- A nota depende do momento: scripts que carregam depois do `load` (GTM, Analytics) fazem a nota cair. Os prints foram tirados com a página estabilizada.
- O plugin só observa. Bloqueio e lista de bloqueio personalizada ficaram de fora, são itens do conceito A.
- O popup insere os dados dos sites com `textContent`, nunca com `innerHTML`, para não abrir XSS dentro da própria extensão.